# Vesuvius Security Report — Submission Report (October 2026 Progress Prize)

Security audit of the Vesuvius pipeline tooling - ScrollPrize/villa. Submission report for the October 2026 Progress Prize by Chase Hendrick, with all verification done locally on private copies and 127.0.0.1 mocks. Every finding carries a plain-terms explanation, exact file/line references, local reproduction evidence, and fix guidance. Live payloads accompany the private GitHub security advisory, which is the link the prize form asks for.

## Contents


**0 — Start here . . . 2**

Vesuvius security report — submission note (start here) . . . 2

**1 — Executive brief . . . 3**

Executive brief — Vesuvius pipeline security report . . . 3

**2 — Consolidated report (finding cards) . . . 4**

The villa artifact-trust report — consolidated disclosure draft . . . 4

**3 — Prize-form entry (Progress Prize, October round) . . . 10**

Progress Prize form entry — paste-ready (October 2026 round) . . . 10

**4 — Digest pin set . . . 12**

**Appendix A — Reproducibility record for the first passes (summarized) . . . 13**

**Appendix B — Community tooling sweep (transcript) . . . 14**

**Appendix C — Offensive tooling / harness (transcript) . . . 21**

**Appendix D — Checkpoint abuse scan (transcript) . . . 25**

**Appendix E — Findings triage register (working record) . . . 31**


*This one document is the entire submission: the start-here note, executive brief, the consolidated report with every finding card, the prize-form answers, the digest pins, and the audit transcripts as appendices. It travels as a single file. Payloads are not part of it — they ride with the private GitHub security advisory in the clearly labeled* `VESUVIUS-AUDIT-EVIDENCE-PACK.zip`*, attached for any maintainer or reviewer who wants them.*

# 0 — Start Here

## Vesuvius Security Report — Submission Note (Start Here)

### Shared as

a single report file — one submission document, no Google Drive or external hosting. The Prize form's link question points at the **private GitHub security advisory on** `ScrollPrize/villa` (filed first; this report and the payload evidence are attached there, visible to the maintainers who review). **Embargo state:** pre-patch — nothing here goes public before a fix ships. **Live payloads: NOT in this report** — raw PoCs stay attached to that private advisory only.

### Read One File

### This report is the whole submission in one document

— the executive brief up top, then the full consolidated report (every finding with its plain-terms explanation, exact file:line, local reproduction, and fix), the digest pins as section 4, and the audit transcripts as appendices. Read it top to bottom; nothing else is required.

The digest pins also ship as a standalone text file attached to the advisory, so anyone verifying downloads can run them directly:

```
shasum -a 256 -c 04-PIN-SHA256.txt
```

### What This Is (and Is Not)

A security pentest of the open-source Vesuvius pipeline software (ScrollPrize/villa and its neighborhood), verified entirely locally on our own copies — no live third-party server was ever probed, and nothing was published. It is *not* a research report and *not* a reading claim: no letters found, none claimed, and none is needed for this to matter.

### Two Rules for Whoever Opens This

### Nothing here goes public before a fix ships

The vulnerability classes described are unfixed as of 2026-10-19; the fix PRs are prepared and maintainer contact is step one of the disclosure plan. In the embargo window this report goes to the maintainers (via the private security advisory) and the Prize readers only.

2. **The checkpoint-loading risk is real today:** until the loader fix lands, verify every `.pth` you download against the pin file above (one `shasum` command).

### Which Form

The security entry goes on the **monthly Progress Prize form** (deadline 31 October 2026, 11:59 p.m. Pacific). Paste-ready answers are in the master document's "Prize-form entry" section — identity fields (email, Discord, terms tick) are filled by Chase himself.

---

# 1 — Executive Brief

## Executive Brief — Vesuvius Pipeline Security Report

### What we did

A white-box security audit of the open-source pipeline the Vesuvius community runs daily (ScrollPrize/villa and its neighborhood), done entirely locally against our own copies and public artifacts. No live server was probed, no one else's systems touched, nothing published. Working with AI-assisted review throughout (Chase directed; assistants wrote much of the code and tests), five passes ran: villa-main's model zoo, the lasagna fit service and surface/label exchange machinery, the new data-access package, a custom detection-harness build, and a passive scan of every checkpoint the community actually distributes — after a first pass on the downstream community CLI that first revealed the checkpoint-trust class (summarized in Appendix A).

### The seven findings that matter

(all locally reproduced, exact file:line in the big report):

| # | In Plain Terms | Class |
|---|---|---|
| 1 | **Opening the community's model files runs programs.** 74 call sites in 56 non-test source files load checkpoints with PyTorch's safe mode explicitly switched OFF; one crafted file = code execution on your machine before any data check | Critical (systemic) |
| 2 | **A model upload over the fit service is a program run.** `lasagna/fit_service.py` base64-decodes a POST field straight into the unsafe loader | Critical (network primitive) |
| 3 | **Anything that writes to your volume while you render it can silently corrupt your evidence.** A mid-run swap produced an ink map internally inconsistent with itself — every check stays green | High (integrity) |
| 4 | **Your password can end up in the log you paste for help.** The deliberate "Input volume:" info line prints the URL with its embedded `user:password` verbatim, before anything else happens (verified at load; the crash path stays clean). If you run with credentialed URLs, grep your logs before you paste them | Medium (secrets) |
| 5 | **Teammate artifact exchange has code-execution surfaces** (`np.load(allow_pickle=True)` from predictable scratch paths) and a **write-escape** in the fresh `vc_reader` cache | High |
| 6 | **Silent data poisoning:** page-stacked label images are misread so ink labels come out empty — and get written into provenance-carrying stores used for training | Medium, mission-critical class |
| 7 | Old-school classics: 18 shell-injection sites in ThaumatoAnakalyptor, catalog downloads with TLS verification **disabled** | Medium |

### Zero-day status (defined precisely)

none of these was documented or fixed before our contact — villa has no `SECURITY.md` and no advisories. So they are zero-days by the "no patch exists" definition. And in the wild? **A passive scan of every distributed artifact (19 fully parsed, 12 more range-scanned; byte-level only, nothing executed) found no weaponized checkpoints** — the channels are clean as of 19 October 2026, which also let us publish the **first digest pin set** for community artifacts.

### Why it matters for the mission

fixes here don't just close exploits — they make the pipeline's evidence trustworthy on purpose: verify-then-load for checkpoints, render-time integrity checks that stop silent corruption, and a reusable census/scanner harness so the bug class becomes a CI property instead of a surprise.

---

# 2 — Consolidated Report (Finding Cards)

## The Villa Artifact-Trust Report — Consolidated Disclosure Draft

Prepared 19 October 2026 for Chase Hendrick. **Everything below was verified locally on our own copies (macOS 15 arm64, CPU-only) — no live third-party server was ever probed or attacked.** Five villa passes are complete as of 19 October 2026 — the model-zoo load path, the lasagna fit service and surface/label exchange machinery, the data-access package, a custom harness/fuzz build, and a passive abuse-scan of the community's distributed checkpoints — preceded by the first pass on the downstream community CLI that opened the engagement (summarized in Appendix A). The villa transcripts are Appendices B–D, the findings register is Appendix E, and results are folded into the finding cards.

### How to read this document

Each finding card has four fields, in this order:

1. **In plain terms** — what this means for a member of the community who has never read the code.
2. **Where it is** — exact file and line in ScrollPrize/villa (branch noted).
3. **How it is reproduced** — the local steps, and what you see happen. Reproduction was **simulated inside our own copies only**; payload artifact names are noted and withheld from circulation.
4. **How it is fixed** — the minimal change, and what it buys.

---

### Part A — the One-Paragraph Version

The community's AI models work by "checkpoint" files: think of them as save files in a video game. Today, in the software everyone runs (villa), opening a save file **executes any code the author of that file put in it** — 74 call sites across 56 non-test source files are wired this way, including the ones shipped as examples of how to run the models and one that accepts such a file **over the network**. So if any of the files the community passes around were ever swapped for a malicious copy, thousands of users' machines would run an attacker's code with nobody knowing: no verification step exists, no digest pinning, and no documented way to report a security problem (villa has no `SECURITY.md`, checked 19 Oct 2026). This report

1. proves the class locally with working (but never circulated) exploits,
2. gives a one-line fix per site plus a reusable detection tool,
3. proposes the guardrails the ecosystem needs (safe loading, digests, a security channel).

### Part B — Finding Cards

#### 1. The Systemic One: 74 Call Sites Across 56 Files Run Any Code that Is Inside A Model File

##### In plain terms

A `.pth`" checkpoint is a special archive; modern `torch` loaders default to opening them safely — just loading numbers, not running programs. Villa's sites **explicitly switch the safety off** (`weights_only=False`), restoring the old behavior in which opening one is a program run. A practical illustration of the stakes: the community's whole workflow — building on models someone else trained — rests on exchanging exactly these files, while swapping a widespread one end-to-end is undetectable by today's pipeline.

##### Where

56 non-test source files, 74 call sites (full-tree `grep` re-measured 19 Oct on the audit clone; the original census pass counted 48 — the narrower model-zoo scope explains the smaller number). Flagship entry points: `vesuvius/src/vesuvius/models/run/inference.py:639` (`vesuvius.predict`, the docs' "how to run a model" entry), `ink_detection/models/checkpoint.py:40`, and the training-resume path `models/utilities/load_checkpoint.py:20`, where the `weights_only` config flag that resuming was told to honor **is read but is never actually passed to** `torch.load`.

### Reproduced

A crafted `.pth` shaped like a real model config whose payload object's `__reduce__` returns `(os.system, (<touch a marker file>))`; run the documented `vesuvius.predict` on it -> the marker file appears **at load time, before any data is read**. Control: the same file with `weights_only=True` raises `UnpicklingError` (the safe loader refuses it). PoC: the sweep's `poc2/` variant for `vesuvius.predict` (`poc2/mk_evil_generic.py`); the full PoC suite and logs ride with the private evidence kit (Appendix A).

### Fix

`torch.load(..., weights_only=True)` at every site, with an explicit module allowlist (`torch.serialization.add_safe_globals` for the config types the code actually needs) — or adopt `safetensors` for new weights; keep a legacy loader only behind an explicit `--trust-checkpoint`; make `load_checkpoint.py` honor `config["weights_only"]`; and add digest-check instructions (pin the LFS sha-256) to every download README.

## 2. Plain HTTP RPC: A Remote Model Upload Runs Anything

### In plain terms

The third finding's server, `lasagna/fit_service.py` (a small HTTP surface the team and colleagues use to push fit jobs and one that is documented loopback by default), accepts an upload field that is **base64-decoded and passed to the same unsafe loader as Finding 1**. For a reviewer: this means a colleague's POST body is a program run — no file ever written locally by the attacker.

### Where

`lasagna/fit_service.py:2382` (`/export_vis`) and `lasagna/fit.py:2110` (`/jobs`, `/optimize` with request-supplied checkpoint paths).

### Reproduced

POSTed a body whose `model_data` is base64 of the crafted object above; the marker file appeared. (PoC in `poc2/`.) Consequence if anyone ever runs the service onto an external card (`--host 0.0.0.0` for remote colleagues), the same result applies to everyone who can reach it.

### Fix

Same safe-loader inputs plus **envelope validation**: accept only safetensors or digest-pinned torch archives, reject pickled request bodies entirely, and refuse `--host`s beyond loopback unless an explicit deployment flag is set.

## 3. From Coworkers' Scratch Files: an Innocuous-Looking Neighbor Path Is Also Program Run

### In plain terms

While growing surfaces, some steps read a small "offsets" file from a *predictable scratch location* — and read it in a mode ("`allow_pickle=True`") that means serious things: objects inside a numpy file are themselves programs run. On a shared cloud or Modal volume, **any process that can write a file to that scratch slot before the analysis starts becomes the attacker**.

### Where

`neural_tracing/winding_models/merge_winding_field.py:662` (`np.load(..., allow_pickle=True)` on a scratch `.npz`) and a sibling `pickle.load` in `utils/io/patch_cache_utils.py:175`.

### Reproduced

poisoned the predictable path with an `.npz` whose object payload carried a marker command; the mark appeared on read. (Poc2 suite.)

### Fix

Convert load mode to the non-pickle side for the offsets (plain arrays suffice — verified by inspection of the producer), check the file owner/timestamps against the start of the run (belt-and-braces), and audit the sibling cache loader

## 4. A Brand-New Data-Access Library Lets A Crafted URL Write Outside its Own Folder

### In plain terms

`vc_reader` (merged into villa the same day this audit started) caches downloaded chunks on disk. It builds the cache path by *joining the URL's path straight into the folder*, so a URL containing `..` segments escapes the cache root **and** the library's own atomic writer then places the file at the attacker's chosen location.

#### Where

`vc_reader/reader/disk_cache.py:187` (`decoded_cache_path()`; the write happens via the library's `atomic_write`).

#### Reproduced

requested a crafted artifact URL containing `../../Users/...` segments; the file appeared outside the cache root. (Poc2 suite.)

#### Fix

resolve + check the prefix before joining (only study principles: if the resolved path does not begin with the cache root, reject; reject URLs containing `..` outright), and reject redundant/symlink escapes at write-time (defense in depth for the future hardened version).

### 5. The Catalog Download Disables TLS Verification

#### In plain terms

The tool that refreshes the data manifest ("which scans exist, after which indices, in which cards") turns certificate checking OFF, then trusts the downloaded catalog; anyone in position on the network can write it. Since the catalog determines what artifacts to fetch, this _____ could point many users at attacker-chosen content — the doorway to the issues in Finding 1.

#### Where

`utils/catalog.py:70–71, 90–91` (`verify_mode=ssl.CERT_NONE`).

#### Reproduced

verified by inspection; we deliberately did not perform a live MITM (not in our permitted scope). The class is trivially demonstrable locally with a test CA, if a reproducible-as-code fix is needed for the patch.

#### Fix

use the default SSL context (normal CA verification); if self-signed mirrors are a real use case, provide `--insecure` behind an explicit flag with a loud warning, and verify digests for whatever flows into the catalog.

### 6. Classic Shell-Injection in ThaumatoAnakalyptor (18 Places), Plus Pixel-Limit Disable

#### In plain terms

Files copied with `os.system(f"cp {path} …")` mean a file-bearing weirdness — a name with spaces, semicolons, or crafted quotes — invents *extra commands*. Old-school, straightforward, real. Same tree also disables the image-decompression pixel guards everywhere.

#### Where

18 `os.system(f"cp {path} …")` sites (first: `mesh_quality.py:34`), plus unconditional `Image.MAX_IMAGE_PIXELS = None` in 7 files.

#### Reproduced

injected command executed, confirmed. (Poc2 suite.)

#### Fix

`shutil.copy` for copies (no shell quote involvement — actually simpler code), `subprocess` with list args everywhere else, and restore pixel guards except behind an explicit config.

### 7. Silent Evidence Poisoning (Correctness with A Safety Implication)

#### In plain terms

Label machinery — the collection of things the models *learn from* — has a silent bug: when label images are stacked as pages (a completely standard layout), they are read with the pages as color channels; the ink pixels disappear into

the "alpha". The step then writes the resulting **empty labels into provenance-carrying label stores**, downstream fine-tunes train on hollow targets and their models report *nothing black* where the source scanned black. The class matters as much as the exploits: it can quietly erase real ink.__ from evidence, and it produces models that look fine and act wrong.

#### Where

`tifxyz_label_transfer/make_label_zarrs.py:27` (`_load_label_2d`).

#### Reproduced

24-ink-pixel page-stack label TIFF -> 0 ink pixels in the written label zarr. (Poc2 suite.)

#### Fix

reject `ndim > 2` for label loaders (or explicitly detect page-vs-channel), and warn before writing an all-empty label layer to a store that claims provenance.

### 8. Everything Else, Filed Small

- The silent wrong-weight "model loads fine" bug: `infer.py:1338–1350` proceeds on 282 missing keys -> a structurally-valid random-weight model runs "successfully". (Fix: fail on missing keys unless explicitly overridden.)
- **Manifest-bomb** self-DoS: a hostile volume claim (declared but absent dims) schedules 270,000 tiles and ~80 GB of scratch stores. (Fix: sane caps unless `--force`, disk quota, occupancy gate.)
- **Turned-mask blank-map** bug: `infer.py:550–569` reads 3-page TIFF masks channel-last; masks multiply to zero and outputs go blank **silently**. (Fix: detect/reject layout; warn on 0% coverage.)

  Crash-quality set: corrupt chunk inside window crashes mid-run, corrupt chunk *outside* the window is silently skipped, `.zarray` string shapes crash on open, mask path/empty file crash the runner, missing extras (`[fsspec[http]]`/`aiohttp`) for URL mode, LZW-write failure leaves a 16-byte junk TIFF.

- Data/auth path **read-only**: the CLI's remote use is GET of user-specified URLs (aligned with **information goals**; no exfil channel found) — a good note to publish against someone's fears.

## Part C — Why Each "Zero-Day" Word Is or Isn't Used (Clear Definitions)

**"Unknown to the maintainer" (0-day):** none of Findings 1–7 was documented or documented-fixed **before** this audit; ScrollPrize/villa has no `SECURITY.md`, no published policy, and no advisories (checked 19 Oct). By this definition, all confirmed findings are zero-day **class** bugs — nothing that stops them exists anywhere in the ecosystem yet.

**"Exploited in the wild?" (answered):** our PoCs exist only locally and were never released. The passive abuse-scan (Part D) read the public distribution byte-level — 19 artifacts fully parsed, 12 more range-scanned, ~2.9 GB, nothing executed — and found **no weaponized artifact in the observed channels as of 19 October 2026**, with every downloaded digest matching its upstream LFS oid. Status: **confirmed and verified unexploited in the observed channels.** What was not in scope: private/authenticated repos and the volume data itself (only model/label artifacts carry pickles).

- **"Weaponization difficulty: low.**" For Finding 1, substituting a plausible-looking checkpoint in a channel without digests requires no technical per-victim work, **which is exactly the risk to emphasize.**

## Part D — the Three Later Passes (All Landed 19 October 2026)

### D1 — Deep store-correctness pass: LANDED (19 Oct evening)

Evidence: quadrant-swap verification, credential-echo logs, and the robustness set — held privately with the evidence kit. New confirmed cards:

### D-1 TOCTOU mid-run swap (High, integrity)

*In plain terms:* if anything writes to the same stored volume while your render is running, your finished ink map can end up a mix of two versions of reality — and every staged check goes green. Think: a colleague's cache job overwrites one chunk mid-run on a shared volume, and your "proof" image becomes internally inconsistent without a

single warning. *Where:* live-store swap 50 ms after device selection; quadrant-level analysis in `results/toctou_summary.txt`; outputs match neither baseline (mean 27.85 vs 28.56/26.70, per-quadrant splits archived). *Fix:* pin chunks with content hashes at read time and re-verify before write-out; refuse to complete when read-change is detected; document shared-volume isolation.

### D-2 Credential echo into run logs (Medium — secrets/hygiene)

*In plain terms:* this one puts **the runner's own password in the run log** — in practice their `dl.ash2txt.org` data account, the `https://user:password@dl.ash2txt.org/…` style URL people embed so non-interactive jobs can pull full-scroll volume data. No password is stored anywhere in the software — the credential exists only if the runner themselves embedded it in the input URL; a runner who passes local paths never has one in play. **Verified channel (the log echo):** the deliberate `LOGGER.info("Input volume: %s", volume_path)` line prints the URL with `user:password` verbatim, before any data is validated — so the password lands in console output, saved run logs, cluster/Modal job dashboards, and the classic case: pasted into Discord for debugging help. Anyone who ever shared a run log shared their password. Repro evidence: `cred_echo.log` (mock URL echoed with creds intact) and `cred_echo_err.log` (the crash path shows a plain traceback with **no** URL — the echo is only the deliberate info line). Location: villa main `infer_full3d_tifxyz.py:1125` (`plan.volume_path`). **Withdrawn claim (stated plainly):** the earlier draft said the reader sends those Basic-auth credentials to *whatever host the data file names* — re-inspection did not support it: the store is built per-volume with a fresh fsspec filesystem (`skip_instance_cache=True`) and auth is derived from each fetched URL's own userinfo, i.e., **origin-bound per URL**; no shared-session cross-host path was demonstrated, and the loopback mock saw credentials only on the credential's own host. Treat artifact-directed forwarding as an unresolved hardening question, not a finding. One honest cone note: URLs without the `vesuvius-challenge-open-data` marker go credentialed; plain `s3://` URLs fall back to the ambient AWS credential chain (env/config) rather than URL userinfo. *Status:* verified locally at `tifxyz_cred/` with a 127.0.0.1-only mock; nothing sent to any real host; abuse scan found nothing weaponized in the wild. *Fix:* redact URLs in logs to scheme+host before echoing (one line), and warn loudly when an input URL carries credentials. *Until it lands:* grep your old run logs for the `://user:pass@` pattern — if it's there, rotate that password.

- **D-3** `--output-prefix` **traversal (Med).** `../../../escaped` wrote outside the segment tree in folder mode; `mkdir(parents=True)` created the escape path. *Fix:* resolve-and-prefix-check before join; reject absolute escapes.
- **D-4 Mask-path hang (Low).** `--mask-path <FIFO>` blocks forever on `open()`; kill-at-60-s repro. *Fix:* open with O_NONBLOCK/timeout, validate regular file.
- **D-5 Clean negative (QA):** metric math (`confusion.py`, `drd.py`, `pfm_weighted.py`, `balanced_accuracy.py`) is all guarded, NaN-filtered — worth one line in the public report.
- Supporting: checkpoint SHA-256 re-verified (`ea4054…984d8a`); amplification numbers (18,097:1, +577 MiB) folded into the 17-row table with PoCs.

### D2 — Custom harness + fuzz lane: LANDED (19 Oct)

Notes: held privately with the evidence kit; tools in the kit's `offensive_tools_villa/` folder (`deser_census.py`, `fuzz_artifacts.py` full sweep 38 cases / 11 non-ok, Hypothesis `tests/test_parser_contracts.py`, `classic/bitflip_classic.py` 90 mutants over 15 seeds, semgrep `rules/` + verified bandit baseline of 206 findings). Stacked with it are new executed/static findings under the **VLT-2693+** namespace (census-verified IDs, no collisions): absurd-scale ×2 (VLT-2695), mask silent-drop (VLT-2694 — loader replaces an ignored mask with a z-derived one, so `_mask` is never None), RCE-marker regression (executed, temp dir), `read_metadata` AttributeError leak on non-dict `meta.json` (VLT-2693, 18/30 examples), native-side decode leaks `ZeroDivisionError` z.tif / `TokenError` npy (VLT-2697). Clean negatives banked: OME-TIFF XXE/SSRF probe **inert** (expat refuses, 0 outbound attempts on a 127.0.0.1 listener), `diff_loader.py` allow_pickle executes across 6 pickle protocols (difference evidence for the fix), villa clone untouched, no third-party contact. The Finding 1 fix diff now has its permanent-prevention tool: the census ID space (max VLT-2692) plus the renumbering rule is documented for future auditors.

### D3 — Passive abuse-scan: LANDED (19 Oct)

Verdict: **no weaponized artifacts in observed public channels** (domenicor046 + scrollprize HF repos, ash2txt community-uploads). 19 artifacts byte-parsed, 12 more range-scanned remotely, 0 weaponized flags; 3 SUSPICIOUS all resolved benign with exact offsets recorded (nnUNet-legacy `_codecs.encode`, `manifest_sha256`-style hex strings); every downloaded artifact's SHA-256 matches its upstream LFS oid. The **zero-day status is now "confirmed and verified unexploited"** in the observed channels, and the report ships a copy-paste **pin set (15 digests)** for the community, plus the standing scanner tool. Limits stated: authenticated/ash2txt-internal models not part of the public distribution were skipped; `v8-in` was not found publicly; volume data itself was out of scope (only model/label artifacts carry pickles).

### Part E — Disclosure Order (Agreed)

**Private advisory first** (`advisory-draft.md` path), targeted at ScrollPrize/villa (and CC: where a component has its own maintainer — ThaumatoAnakalyptor). Bundles: **One advisory** for the checkpoint-loader family (Findings 1 + 2 + training path + partial-weights); one for the scratch-file/cache/TLS trio (3+4+5); public issues afterwards for the annex (6–7 + everything-else list) once fixes land.

2. **Fix PRs**: Layer 1 (safe loader + allowlist + honored flag + missing-keys guard); Layer 2 (cache-prefix check; SSL default; scratch-file hardening); Layer 3 spot fixes.
3. **Public report** (this document, minus live payloads; reproduce script only after a fix lands).
4. **Progress Prize entry** — bundle under the month's rule; a report + reusable detection tool + fix diffs is one coherent contribution.

### Part F — Reproduction Master List (All Local; Nothing Executed Against Any Third Party)

| # | Finding | One-Line Local Repro | Expected Visible Result |
|---|---|---|---|
| 1 | checkpoint RCE (model zoo + training resume) | build payload via `poc/mk_evil_ckpt.py`, run `vesuvius.predict` on it | marker file created at load time; safe loader control raises `UnpicklingError` |
| 2 | fit-service HTTP RCE | `poc2/` script POSTs base64-pickled `model_data` to a locally spawned `fit_service` on `127.0.0.1` | marker file created during request handling |
| 3 | scratch-file npz RCE | poison a scratch `.npz` with an object payload, trigger the reader on the same slot | marker file appears when the run reads the scratch file |
| 4 | cached-URL traversal write | request crafted `s3://…/../../…` artifact URL through `vc_reader` against local mock | file appears outside the cache root |
| 5 | catalog TLS off | inspection (no live MITM in scope) | — |
| 6 | shell injection | name with `;` payload through the ThaumatoAnakalyptor copy path | injected command executes |
| 7 | silent label poisoning | page-stack label TIFF with 24 ink px through `_load_label_2d` | label zarr contains 0 ink pixels, provenance header intact |
| 8 | annex items | per-item one-liners in the sweep/audit notes | crash traces / silent-zero outputs as described |

**Boundaries (stated plainly):** everything above ran on our own clones and loopback-only mocks. The real released weights were never executed; the production container path was inspected, not run; and no findings are asserted about correctness of anyone's models — only about the trust machinery around them.

---

# 3 — Prize-Form Entry (Progress Prize, October Round)

## Progress Prize Form Entry — Paste-Ready (October 2026 Round)

Form: https://docs.google.com/forms/d/e/1FAIpQLSc4flEfgK2nyjoczz2_U_XrIGMlgrnSknWatLqrFPnbtKfZwg/viewform
Deadline: **31 October 2026, 11:59 p.m. Pacific.** Per established convention: Chase fills in the identity fields and accepts the terms himself; nothing is submitted by the assistants.

### Q1 — Email

*(Chase supplies. "Record my email address" stays ticked.)*

### Q2 — Full Name

Chase Hendrick

### Q3 — Team Description

```
Individual. I directed the work and reviewed everything; AI coding
assistants (Claude Code, Codex and Grok) wrote much of the code, tests and
report text under my direction. I filed every disclosure step myself.
```

### Q4 — Discord Display Name

*(Chase supplies his exact display name, or leaves blank.)*

### Q5 — URL of Your Open Source / Publicly Available Contribution

**Primary link (this round): the private GitHub security advisory on `ScrollPrize/villa`.** File it first — attach this report (the one PDF) plus the clearly labeled evidence pack `VESUVIUS-AUDIT-EVIDENCE-PACK.zip` (every payload and effect artifact, a finding->artifact map, and the `MANIFEST.sha256` inside). Reviewers who want the payloads can have them: the advisory carries the pack; on-request handover works the same file. The form asks for a URL and has no file slot, so the report and its payloads travel inside the advisory, exactly where the maintainers who review can read everything without ever touching a broken-embargo copy of the findings. Paste the advisory URL here once filed.
**When a fix PR lands on `ScrollPrize/villa`** (or the public sanitized release is made — report + scanner + pin set, Apache 2.0), add these as extra lines:

```
<fix PR URL on ScrollPrize/villa>
https://github.com/ChaseHendrick/checkpoint-scanner
```

The `checkpoint-scanner` repository holds this report, the scanner tool, the digest pins, and the labeled evidence pack. While the findings are unfixed it stays **private** — reviewers read it once they are added to the repo (same control as the advisory), or after the fix ships it goes public with the sanitized edition. If it is visible to reviewers by form day, it is the cleaner first line. **Note on timing:** the report contains an unfixed vulnerability class; the *public* version is the sanitized one (repro commands, evidence, fixes — live payloads attached only to the private GitHub security advisory, which was filed first). If the fix has landed by form day, the fix PR link becomes the strongest first line.

### Q6 — What Is Your Contribution?

```
A security audit of the software the Vesuvius community runs on the public
scan data — the pipeline machinery, not a reading.

1. Scroll data. No scan data was altered and no model quality is claimed.
The work ran locally against the public pipeline (ScrollPrize/villa and
neighbors) and the files the community actually distributes: public
checkpoints on Hugging Face (domenicor046 reader-v2/v3 and ink9um-dense;
scrollprize ink_9um, winding_model_9um, hecate) and dl.ash2txt.org
community uploads, checked byte-level without executing them.

2. How it helps reading. The trust machinery can silently damage what
becomes evidence. Loaders run arbitrary code from any exchanged checkpoint
(74 call sites in 56 files load model files with PyTorch's safe mode
switched off; a crafted file executes before any data check). A write to a volume during
rendering can leave an ink map that internally matches two file generations
at once, with no error raised. Masks and labels can silently come out empty
(page-stacked label TIFFs are misread and hollow labels are written into
```

```
provenance-carrying stores used for training). Each fix makes surfaces,
renders and ink maps trustworthy on purpose, which is what a first-letters
attempt needs; until then, "no ink" and a broken artifact look identical.

3. What it enables. Verify-then-load for checkpoints (safe weights_only
loading with an explicit module allowlist), a published SHA-256 pin set for
every distributed artifact (the first for ash2txt community uploads — one
shasum command now catches a substituted model file), render-time integrity
verification that makes concurrent-write corruption detectable, and a
reusable audit harness (deserialization census, parser contract tests, and
an offline checkpoint scanner with a CLEAN/SUSPICIOUS/WEAPONIZED verdict)
so this bug class is caught by tooling instead of by surprise. It also
proposes the repo's first SECURITY.md so future reports have a channel.

4. Evidence. All local, all reproducible from the report: an executed
marker-file PoC for the checkpoint loader (withheld from circulation
pending a fix, as standard practice), a quadrant-level analysis showing the
mid-run-swap output matches neither file baseline, and a passive abuse scan
of the community's distributed artifacts (19 fully parsed, 12 more scanned
by range request; ~2.9 GB read, nothing executed) certifying that no
weaponized artifact existed in the observed channels as of 19 October 2026.
The report lists every finding with exact file and line, reproduction and a
one-pattern fix; a disclosure timeline it follows: private advisory first,
fix PRs, then public report. Scans/certifications carry claim labels and
limits; no letter in any scroll is claimed and none is needed for this to
help.
```

*(Drafted ~330 words to keep under any practical form limit; trim the parentheticals further if the field fights back.)*

### Q7 — Terms and Conditions

Tick **Yes, I agree** after reading. The method is released under Apache 2.0 on public main; note for the review, if asked: the scanner tool and report are Apache-2.0, and villa patches follow each patched file's license (villa top-level MIT).

---

## 4 — Digest Pin Set

```
# Verify-then-load pin set — as measured 2026-10-19 (byte-level, nothing executed)
# Usage: shasum -a 256 -c pin-check.txt   (from the folder holding the files)
# Or:    shasum -a 256 <file>            (compare against the value below)
# Caveat: downloaded copies only; re-measure any NEW version rather than trusting a stale pin.

ea405417450abd8ace1b8ff79ebce3adb646c5e48ab95da46844d77efe984d8a  reader-v3.pth
c9776873cc9c44d5d24f2ba3126986cb5a81fba3d2929ae5b89c288c43d86d1e  never_seen_0841_w00.jpg
654ec5acec2b6c4788d9cb326e2f0b8c2c730584949a934ef775db7f6ab5d3a6  reader-v2-step040000.pth
6bad92971b029857f23d1ab46a623b0f2cd6c9605c05d1939c8f859b0d98f79b  reader-v2-init-ft12k.pth
a69e9cf23263d4b17a85f05501333408f923f67f65b6f4ebc6c4539ceb1e81ec  reader-v2/train_config.json
1d7b99bc641b459736a762b2a1d8c357f61ada4f0117c24c7327b6a1293ba1eb  ink9um-dense/dense9um-w016excluded-step075000.pth
a92875559e654a35a0702e3563a95914131692ae8b832a0f86ac8e239947897d  ink9um-dense/dense9um-w016excluded-step060000-best.pth
4e23f3cd6e5742a2911431145e825fe4523f8abdcb8790615e209dfc20be7977  ink9um-dense/dense9um-all7-step075000.pth
e60cee6b2c08a021ddfa9683869dab91787531cef762d833cc1f21fdee7fa114  ink9um-dense/control-manuallabels-step075000.pth
093cdb7dd03d881ba280be2b9b9fcb6ecf4f36594399a5a99e89538ad836736f  ink9um-dense-labels/ink9um-dense-pseudolabels.tar
e635558ae6a1a807a7e5ec1e83adfd45bc3c0ac53883ea43f1d4e085d62a9cab  scrollprize/ink_9um/hybrid_3d2d-seed42/step-075000.pth
2aeaa85a35ef28d7bc7bf3e848c4a6a91385e9132710927fdba41133c4ecb28f  scrollprize/ink_9um/hybrid_3d2d-seed43/step-075000.pth
805a868c5ef518e4edb567ac2ddc63dfbf870f21b1164ae1642baa1781ad8f02  scrollprize/winding_model_9um/ckpt_final.pth
4b1b890950f8b102511eba1bbdc350fa1662ef1039a223f608af417211cf6e05  scrollprize/winding_model_9um/config.json
809f4f10f7cb7afa19b4bee0f7d2ab31edd7e11b664f9f210cc9c17f22fcfe5d  scrollprize/hecate/hecate_9.6um.pth
fa2de3827ebd247ff2d33df1b6f899ea79d5269036cf16765997c62f0e9988c7  scrollprize/hecate/hecate_2.4um.pth
c232c18a1a86cfb91257a00db13288202bb8ae33732ba26f7291a9b8adb8da59  scrollprize/hecate/hecate.py
774a3bbd9cf6d0c1fdc7ce2a6c953b91620573a4f96196053fcc98078ca6b2f2  dl.ash2txt.org community-uploads/bruniss/old_models/Dataset
# Note: the ash2txt community upload has NO upstream-published digest; this file is
# the first published pin for it. HF artifacts above match their published LFS oids.
```

## Appendix A — Reproducibility Record for the First Passes (Summarized)

The engagement opened with two passes whose work predates the villa findings: an audit of the downstream community CLI (the `koine_machines` package the Reader V3 release runs on), and a deep correctness pass on store handling. They proved the checkpoint-trust class end-to-end before the villa census confirmed it at villa scale. To keep this edition focused on ScrollPrize/villa, both transcripts are summarized here and held privately — attached to the security advisory when it is filed, with the SHA-256 manifest of every artifact:

- **First pass (community CLI).** A crafted `.pth` executes its payload at load time, before any data check; the safe loader (`weights_only=True`) refuses the same file. The villa-internal form of this is Finding 1's 74-site census.

### Deep store pass

Produced the Part D cards: mid-run-swap evidence corruption (quadrant-verified), the credential-echo log finding (Medium, after the cross-host claim was withdrawn on re-inspection), the traversal and hang robustness set, and the clean metrics negatives.

- The 17-row cross-tool summary from the villa sweep is preserved in Appendix B.

# Appendix B — Community Tooling Sweep (Transcript)

## Community Tools Security Audit — Vesuvius Challenge Tooling (White-Box, Local-Only)

Audit date: 2026-10-19. Auditor scope owner: this session (subagent deliverable read-only for the repo owner). Working local clones (all under the private audit workspace):

| Clone | Commit | Content |
|---|---|---|
| `villa/` | `23876bef6a10c928abf167e963f9755534cec2dd` ("add vc reader (#2157)", merged 2026-10-19) | villa monorepo at tip: `vesuvius` package, `vc_reader`, `lasagna`, `spiral-fitting`, `dinovol`, `deprecated/thaumato-anakalyptor`, CI, docs |
| `villa_inkpipline/` | branch `merge-ink-pipelines` worktree (downstream community CLI) | present only as a provenance cross-check — **covered by the first-audit pass (Appendix A); not re-reported here** |

Test venv: private audit workspace `.venv` (python 3.12.15, torch 2.10.0, zarr 2.18.7, numpy 2.2.6, `vesuvius` installed editable).

Hard constraints honored: all PoCs ran against local files and one loopback-only HTTP service (`127.0.0.1:18811`, started and killed inside the PoC script). No requests to ash2txt.org, dl.ash2txt.org, Hugging Face, GitHub prod, Modal, ScrollPrize servers, or any Discord. No public posts. Chase's repos and credentials untouched (only doc-level reads in `~/Scrolls/docs`, nothing opened under `Scrolls-private`).

PoC artifacts (all local, all safe-to-run markers only): `poc2/` of the private evidence kit

- `mk_evil_generic.py` — builds malicious `.pth` payloads
- `poc_vesuvius_load_checkpoint.py` — **executed, RCE confirmed** (PoC 1)
- `poc_fit_service.py` — **executed, RCE via HTTP POST confirmed** (PoC 2a); traversal probe **rejected by existing validation** (PoC 2b, honest negative)
- `poc_winding_allowpickle.py` — **executed, RCE confirmed** (PoC 3)
- `poc_vcreader_cache_traversal.py` — **executed, out-of-cache-root write confirmed** (PoC 4)
- `poc_thaumato_cmdinject.py` — **executed, injected commands ran** (PoC 5)
- `poc_label_axis.py` — **executed, silent label corruption confirmed** (PoC 6)

---

### 1. Findings Table

Severity: CRIT = arbitrary code execution (ACE) reachable from artifact ingestion; HIGH = ACE in unusual-but-real conditions or serious integrity/control-plane break; MED = corruption / cross-user boundary break / DoS-driven training pollution; LOW = robustness/hygiene.

#### 1 — Villa `vesuvius` Package (Model-Zoo CLIs)

**Component:** Checkpoint deserialization, systemic `weights_only=False`

**Severity: CRIT**

**Exact Location:** Flagship sinks: `vesuvius/src/vesuvius/models/run/inference.py:639` (`vesuvius.predict`), `vesuvius/ink_detection/models/checkpoint.py:40`, `utils/models/load_nnunet_model.py:235,517`, `models/utilities/load_checkpoint.py:20`, `napari_trainer/inference.py:27`, plus **48 census-counted source files** (pin `@23876bef`; 19-Oct re-grep: 74 call sites in 56 non-test files) in villa (vesuvius/lasagna/dinovol/deprecated) using `torch.load(..., weights_only=False)` — see §1a list

**Status: CONFIRMED (executed)**

**Minimal Local PoC:** `poc2/poc_vesuvius_load_checkpoint.py` on `mk_evil_generic.py` output: marker file created at load, before any data access; control `weights_only=True` -> `UnpicklingError`

**Suggested Fix:** Same as reader-v3-audit fix: safe loader + `add_safe_globals` allowlist; ship `safetensors`; explicit `--trust-checkpoint` opt-in

**Disclosure Route:** Private GitHub security advisory on `ScrollPrize/villa` (Security tab exists; no `SECURITY.md`)

## 2 — Lasagna Fit Service (`fit_service.py`, VC3D-Adjacent HTTP Optimizer Service)

**Component:** `/export_vis` endpoint loads arbitrary bytes as pickle

**Severity: CRIT (local/RCE)**; CRIT->HIGH if run with `--host 0.0.0.0` for LAN colleagues

**Exact Location:** `lasagna/fit_service.py:2371-2382` — POST body `model_data` (base64) -> `NamedTemporaryFile(.pt)` -> `torch.load(..., weights_only=False)`; same primitive at `:758` and `:1969`, and `fit.py:2110` for `/jobs`+`/optimize` with request-supplied `model_input` paths

**Status: CONFIRMED (executed)**

**Minimal Local PoC:** `poc2/poc_fit_service.py`: POST `/export_vis` `{"model_data": <b64 pickle with os.system payload>}` -> marker created in service process (loopback only)

**Suggested Fix:** Reject unsigned weight payloads: pass only model state dict paths from a server-side job registry; if client-supplied bytes are required, `safetensors.load_file()` only; mark `weights_only=True`; consider auth (unix socket instead of TCP like `trace_service`)

**Disclosure Route:** Private advisory `ScrollPrize/villa` (fit_service is the prize-active Lasagna path — likely fastest team response)

## 3 — Villa `vesuvius` Neural Tracing (Winding Models)

**Component:** `np.load(..., allow_pickle=True)` cache in shared scratch

**Severity: HIGH** (ACE if `patch_offsets.npz` crafted into a predictable scratch/output dir; realistic on shared volumes/Modal-like environments)

**Exact Location:** `vesuvius/src/vesuvius/neural_tracing/winding_models/merge_winding_field.py:662` (`offsets_path = scratch / "patch_offsets.npz"`, `np.load(offsets_path, allow_pickle=True)`); sibling: `utils/io/patch_cache_utils.py:175` `pickle.load` on cache files

**Status: CONFIRMED (executed)**

**Minimal Local PoC:** `poc2/poc_winding_allowpickle.py`: `np.savez(patch_offsets.npz, offsets=np.array([RCE()],object))` then the exact sink call -> marker

**Suggested Fix:** `allow_pickle=False`; version/fingerprint the cache file; cast arrays to native dtypes on save and load with `np.load(..., allow_pickle=False)`; store offsets as fp32 npz

**Disclosure Route:** Private advisory villa

## 4 — Vc_reader (PR #2157, New Data-Access Package)

**Component:** Decoded chunk-cache path from URL without `..` normalization

**Severity: HIGH (arbitrary file write via crafted catalog/metadata URLs)**

**Exact Location:** `vc_reader/src/vc_reader/reader/disk_cache.py:187` `decoded_cache_path()` -> `os.path.join(cache_dir, scheme, netloc, path.lstrip("/"))` with raw URL path; writes via `:74` `atomic_write()` (`.zarray`/`.zattrs`) and C++ chunk appends to the same root

**Status: CONFIRMED (executed, library functions)**

**Minimal Local PoC:** `poc2/poc_vcreader_cache_traversal.py` — crafted `s3://bucket/x/../../(×20)Users/...` URL -> `.zattrs` written **outside** the cache root

**Suggested Fix:** `posixpath.normpath` and then reject results outside a resolved cache root (containment check); strip `./..` key segments from URL paths at the catalog layer too; raise on them

**Disclosure Route:** Private advisory villa (PR #2157 is 0-days old — maintainer contact = PR authors)

## 5 — ThaumatoAnakalyptor (in Villa `deprecated/`)

**Component:** Shell metachar injection via artifact filenames (`os.system(f"cp {path} …")`) — **18 sites**

**Severity: MED** (cross-user RCE on shared folders / low local impact; trivially fixed)

**Exact Location:** `mesh_quality.py:34`, `finalize_mesh.py:19,26`, `grid_to_pointcloud.py:778`, `split_mesh.py:33`, `instances_to_graph.py:1218`, `mesh_to_surface.py:381`, `mesh_transform.py:34`, `mesh_to_mask3d_labels.py:40`, `mesh_merger.py:30`, `graph_problem/graph_solve.py:101-225` (`rm -rf`/`mkdir` with fixed strings — low)

**Status: CONFIRMED (executed identical sink)**

**Minimal Local PoC:** `poc2/poc_thaumato_cmdinject.py` — filename `benign.obj; touch RCE_marker.txt;` -> two injected commands executed

**Suggested Fix:** `shutil.copy2` or `subprocess.run([...], shell=False)`; also stop declaring `Image.MAX_IMAGE_PIXELS = None` unconditionally (7 files)

**Disclosure Route:** Public issue acceptable (low-blast, archived code still fetched/run by newcomers); or one advisory covering loader+cmd-injection

### 6 — Villa `vesuvius` Tifxyz Label Transfer (Labels Pipeline Used to Build Community Label Data)

**Component:** Axis mishandling of 3-D label TIFFs -> silent wrong labels

**Severity: MED (integrity: poisoned labels breed model errors)**

**Exact Location:** `vesuvius/src/vesuvius/tifxyz_label_transfer/make_label_zarrs.py:27-33` `_load_label_2d()`: `np.squeeze` + `image[...,0]` for any 3-D input (page-stacks destroyed)

**Status: CONFIRMED (executed)**

**Minimal Local PoC:** `poc2/poc_label_axis.py`: `(2,8,10)` page-stack with 24 ink pixels -> loaded as `(2,8)` with **0** ink pixels, no error, provenance attrs attached

**Suggested Fix:** Detect axis explicitly (page-stack vs channel-last) or reject ndim≠2; refuse to write zarrs whose loaded ink pixel count is implausibly low vs source metadata

**Disclosure Route:** Public issue (correctness), with PRIVACY note: affects community label datasets' downstream models

### 7 — Villa `vesuvius` Tifxyz Reader

**Component:** Predictable `/tmp` mmap cache with attacker-guessable name -> local cross-user cache poisoning

**Severity: MED (cross-user integrity on shared boxes)**

**Exact Location:** `vesuvius/src/vesuvius/tifxyz/reader.py:453-477` `_mmap_cache_path()` (sha256 of path+size+mtime under `/tmp/vesuvius_tifxyz_mmap_cache/`) and `exists()` re-use -> TOCTOU/symlink race with another local user

**Status:** Code-reviewed (needs a second local user to demonstrate race; not executed)

**Minimal Local PoC:** n/a (multi-user harness)

**Suggested Fix:** Use `tempfile.gettempdir()` per-UID subdir (respect `$TMPDIR` semantics) + `O_EXCL`/`os.replace` after `lstat` checks; or keep memmap cache per-process dir

**Disclosure Route:** Advisory or public issue

### 8 — Villa `vesuvius` Catalog Client (`utils/catalog.py`)

**Component:** TLS identity check disabled on data-server refresh

**Severity: HIGH** (MITM of catalog refresh yields attacker-controlled `scrolls.yaml`/`cubes.yaml`, defining the paths people fetch)

**Exact Location:** `vesuvius/src/vesuvius/utils/catalog.py:70-71,90-91`: `ssl_context.check_hostname=False; ssl_context.verify_mode=ssl.CERT_NONE` for both `scrape_website()` and `collect_subfolders()`

**Status:** Static (defect unambiguous; not executed — MITM harness skipped)

**Minimal Local PoC:** n/a

**Suggested Fix:** Remove the two lines; default context verifies certs; if an internal CA is required, pin it via `ssl.load_verify_locations` and never flip `verify_mode`

**Disclosure Route:** Private advisory villa

### 9 — `trace_service.py` (VC3D Neural Tracer Backend)

**Component:** Unix-socket server: per-request arbitrary paths -> in-service checkpoint loads; socket perms default

**Severity: MED** (local cross-user ACE on workstations; same-user otherwise)

**Exact Location:** `vesuvius/src/vesuvius/neural_tracing/trace_service.py:84-86` (socket bound without `chmod 0600`), `:124` `load_checkpoint()` default `weights_only=False`; copy requests may override `checkpoint_path` per-request (`_build_copy_args`, ~lines 200-220) and dense requests accept arbitrary

`volume_path`/`tifxyz_path`/`tifxyz_out_dir` once validated only for presence

**Status:** Static (inherits confirmed PoC 1 loader class)

**Minimal Local PoC:** PoC 1 evidence establishes the load primitive

**Suggested Fix:** `os.chmod(socket_path, 0o600)`; restrict per-request paths to the volumes the service was started for; `weights_only=True`

**Disclosure Route:** Private advisory (bundle with finding 1)

### 10 — ThaumatoAnakalyptor (Legacy-Era Code)

**Component:** Plain `pickle.load()` on graph/patch state — **community artifact exchange class**

**Severity: HIGH** (community members hand each other `graph.pkl`/`point_cloud.pkl`/`harmonic_uvs.pkl` daily)

**Exact Location:** `deprecated/thaumato-anakalyptor/ThaumatoAnakalyptor/graph_to_mesh.py:35,100,1332,1430,1717`, `instances_to_graph.py:345`, `instances_to_sheets.py:499`, `mesh_merger.py:432,506`, `patch_cache_utils.py:175`, `neural_tracing/inference/infer_streamline.py:266` (own-temp payloads, lower)

**Status:** Static (pickle primitive = confirmed by PoCs 1/3)

**Minimal Local PoC:** n/a

**Suggested Fix:** Migrate graph pickles to `torch.save`+`weights_only=True` (dict of arrays) or HDF5/NPZ; document "never load another member's .pkl"

**Disclosure Route:** Private advisory; add explicit warning in deprecated repo README

### 11 — Villa Docs/ThaumatoAnakalyptor

**Component:** `Image.MAX_IMAGE_PIXELS = None` (decompression-bomb guard off) in 7 files + `OPENCV_IO_MAX_IMAGE_PIXELS=4294967295` instructions

**Severity:** LOW (memory DoS from hostile texture/PNG)

**Exact Location:** `graph_to_mesh.py:29`, `finalize_mesh.py:9,82`, `mesh_quality.py:8`, `cut_tif_region.py:5`, `split_mesh.py:17`, `mesh_to_surface.py:22`, `instructions.txt:53-54`

**Status:** Static

**Minimal Local PoC:** n/a

**Suggested Fix:** Cap pixel budget per tool with config; bombs should fail with an actionable error

**Disclosure Route:** Public issue

### 12 — Fit_service `/objects` Upload

**Component:** (NEGATIVE — **defense works**)

**Exact Location:** `fit_service.py:596-604` `_segment_manifest_hash` rejects absolute/`..` artifact paths before writes

**Status:** Executed probe rejected (PoC 2b)

**Suggested Fix:** keep; add regression test

### 13 — Villa CI (.Github/workflows)

**Component:** (NEGATIVE — **good hygiene**) least-privilege `permissions: {}`, repo-owner guards, no `pull_request_target`+secrets

**Exact Location:** `progress-prizes-production.yml:37`, `large-pr-review-gate.yml` (permissions contents:read only), `test-vesuvius.yml`/`deploy-vesuvius.yml` use `pull_request`/`push:main` only

**Status:** Reviewed

## 1a. the Systemic `weights_only=False` Census (Villa Main @ 23876bef)

48 source files in the census pass `@ 23876bef` (tests excluded); 19-Oct full-tree re-grep: **74 call sites in 56 non-test files** — treat 48 as the conservative floor. Representative user-facing/CLI-reachable sinks beyond finding 1's flagship sites:

- `models/run/inference.py:639` (`vesuvius.predict` CLI — the model zoo entry people run on community checkpoints from HF `scrollprize` or dl.ash2txt.org mirrors)

- `models/utilities/load_checkpoint.py:20` (training resume), `models/training/train.py:1718`
- `neural_tracing/nets/models.py:303,310,329-331` (`trace_service` / VC3D Neural Tracer; `weights_only` *defaults* False)
- `neural_tracing/inference/displacement_helpers.py:180`, `infer_global_extrap` path; `winding_models/infer_winding_volume.py:246,1266`, `train_winding_model.py:620`

  `neural_tracing/tracers/fibers/sheet_strip/infer.py:418` (loads `vol_spec` **dataset config** out of a checkpoint — attacker-controlled zarr paths -> downstream data reads), `volume_afv.py:38` (same), `legacy/infer.py:13`, `patch_model.py:90`, `heading_model/model.py:156,163,173`
- `ink_detection/models/checkpoint.py:40`
- lasagna: `common.py:163`, `fit.py:2110`, `fit2tifxyz.py:1133`, `fit_service.py:758,1969,2382`, `lasagna_analyze.py:445,843`, `lasagna_fit_data.py:656`, `preprocess_cos_omezarr.py:1548`, `train_tifxyz.py:703`, `train_unet_3d.py:510`
- dinovol: `pretrain.py:462,1991`, `model/model.py:722`, `model/dinov2_eva.py:891`, `eval/napari_visualizer.py:398`
- `models/build/pretrained_backbones/dinov2.py:200,264,284`, `dinovol_2_eva.py:756`

  Positive outlier to cite in the advisory: `spiral-fitting/fit_session.py:867` **rejects** "legacy pickle checkpoints" explicitly, and `models/run/external_models/load_resnet.py:71` uses `weights_only=True`, `fiber_trace_3d/infer.py:99,127` too. Proposed fix text can lift these examples.

Class note: the checkpoint-trust class was first proven end-to-end on the downstream community CLI (Appendix A); the census and file list above are the villa-specific form of the same lesion. The advisory should lead with the villa evidence.

---

### 2. Ranked “Most Likely to Be Rewarded if Disclosed Properly”

Context on which channels pay, from this repo's own docs:

- `scrollprize.org/docs/23_open_source_prizes.md` — monthly **best submission / bug fix** awards (historically $1k–$2.5k for modest tooling fixes; larger tooling rounds $10k–$20k).
- `scrollprize.org/docs/15_winners.md` — precedent for tooling fixes/refinements being paid ($1k "Schilling ink detection refinements", $2.5k bugfix-class rounds, $500 rounds).
- GitHub **private security advisories** on `ScrollPrize/villa` — preferred for RCE-class; the Security tab exists; there is **no** `SECURITY.md`, so a draft advisory + a direct report via the tab is the route.

Shortlist (highest expected reward -> hygiene):

**Private advisory: systemic** `weights_only=False` **+** `fit_service /export_vis` **RCE** (findings 1+2, with PoC 1 & 2a attached). One coordinated report; offer the census list. Probably worth a progress-prize mention *after* the fix lands, and it removes an active community risk on the night a new reader checkpoint ships (release day = max exposure). Recommended severity statement: "reachable via community checkpoint swap or MITM of dl.ash2txt-hosted model caches".

2. **Private advisory: winding-field** `allow_pickle` **+ graph pickles + patch caches** (findings 3+10). Team-internal secondary; pairs with the standard `np.load` migration.
3. **Private advisory bundle:** `catalog.py` **CERT_NONE + vc_reader cache traversal** (findings 8+4). Clear fixes, small diffs, PR #2157 authors are the likely reviewers — fastest possible merge-to-fix.

**Public bug report (no PoC code): thaumato command-injection sweeps**

(finding 5, with `shutil.copy2` fix proposal and the 18-file list) — lower harm but iconic; probably accepted whenever someone sees it; a $500-class fix if bundled with label tool correctness.

5. **Public issue:** `_load_label_2d` **axis bug + set-max-pixels cleanups** (findings 6+11) — fix makes the labels dataset pipeline safer and removes a DoS root.

6. **MED work: tifxyz `/tmp` cache + `trace_service` socket perms** (findings 7+9) — security advisory if combined with a shared-workstation deployment doc; avoids a shared-box ACE class that Modal-host batch jobs don't see.

Reward-caveat honestly stated: ScrollPrize's prize culture rewards *impactful fixes* most; the RCE class is the only one with practical scope. Keep the private advisory channel early; progress-credit tracking after the fix.

---

### 3. Ink-Label / “Verified Letters” Integrity Analysis (Local Only)

Documents in this clone confirm the flow: `scrollprize.org/docs/22_firstletters.md:148` — verified quotes come from **panels of papyrologists after 'thorough technical review'**, not from any artifact ingest. No code path in villa promotes a label file automatically to "verified letters" (greps for `verified` in label/transfer code return none). Therefore:

- A malicious label tifxyz / npz **cannot** directly flip verified letters — the guardrail is human/logistic.

  The real vector is *indirect deception*: a poisoned label zarr (or a label-TIFF read with the `_load_label_2d` axis bug, or wrong labels trained into a checkpoint shared back into the community) influences the *pictures and probability maps the reviewers look at*, i.e. “attacker-controlled evidence” into the judging process. Root-strengthening items in order:

· `_load_label_2d` axis bug (finding 6) makes label ingestion silently wrong for multi-page exports, including politely-provenanced ones — pure correctness fix, no attacker needed.

  Dataset provenance: `reader-v2-labels` and `aligned-scrollprizeorg-21slices`-class label sets ride on HF with no digest pins (the first-audit pass already flagged pinning); label zarrs written via `make_label_zarrs.py` accept `extra_attributes` — enforce a checksum + expected source-uuid check on load (`overwrite=False` semantics already discourage accidental overwrite).

· The review panel pipeline itself is off-code (UI screenshot as images); no attack surface from this repo.

  Submitting-side review (`docs/34_prizes.md:236,300`) is human-team; nothing here suggests a programmatic verifier to poison. Evidence quality attack = the real exposure, mitigated by the fix above and by keeping message integrity between HF cache, disk, and rendering (the vc_reader cache-traversal finding 4 is the file-level integrity piece to close).

### 4. Secrets / Logs / Modal Notes (Docs-Only; Nothing Opened)

- `~/Scrolls/docs/compute.md`, `engine.md`, `WORKFLOW.md` describe **Modal/RunPod pay-per-second GPU jobs** as the community norm (e.g. A10 6.5h first Letters run $13.53); no named secret stores in docs; nothing prints or writes credentials by default.

  Grep of villa main found **no** logging of secret values (`AWS_SECRET`, `hf_token`, basic-auth) in checkpoint-carrying code; Basic-auth URL userinfo and AWS env creds stay process-local. Improvement worth one $500-class fix: redact credential echoes in errors and run logs (see the Part D credential-echo finding).

  `vesuvius.vesuvius.is_aws_ec2_instance()` probes `http://169.254.169.254/` over plaintext (fine for IMDS, but it's the default path even when HTTPS is available; on custom endpoints some clouds return 200 — worth a harden: use `AWSCONFIG` managed IMDSv2 token). LOW.

  No SSRF-via-fsspec finding beyond the first-audit pass's existing notes: villa main's data layer pins to `s3://` handlers or user-provided schemes; the fsspec `open_zarr`-family risk (arbitrary scheme dispatch -> e.g. `sshfs`/`dbfs` gadget chains) is real but requires attacker-chosen URLs — same status as that pass (recommend the scheme whitelist below).

### 5. Defense-In-Depth Checklist for Community Repos

#### Deserialization

1. Ban `torch.load(..., weights_only=False)` project-wide (`grep -r` gate + pre-commit hook), keep `add_safe_globals` allowlist for exactly-far config dicts (`OmegaConf`, `argparse.Namespace`, `zipfile.Path` if-ever).
2. Publish model artifacts as `safetensors` + a tiny `config.json`; retain `.pth` only in archive branches.

3. `np.load`: `allow_pickle=False` everywhere; rewrite caches that store integers or floats as object arrays.
4. Graph state: replace pickle with `.npz`/HDF5 (+ a version header), or `torch.save`+`weights_only=True` for uniform handling.
5. Require `--trust-checkpoint` flag for any path that would resume/restore *training state* (optimizer, RNG) rather than plain weights.

**Distribution integrity**

6. HF release docs must pin sha-256 and show a `sha256sum` or `hf download` verify step in copy-paste block.
7. Add digest-check in the model-zoo CLI: after download, verify printout `PASSED sha-256: <known>`; refuse to run when `REQUIRE_DIGEST=1`.
8. `metadata.json`/catalog: verify signature chain (a ScrollPrize-signed manifest) before swallowing artifact URL list.

**Path & process hygiene**

9. `decoded_cache_path()` (and any cache keyed on URL): `normpath` + containment check (`os.path.realpath(target)` must start with `os.path.realpath(cache_root)`).
10. Replace `os.system(f"cp …")` with `shutil.copy2` (Thaumato 18 sites, with regression test that produces a failing command at test time).
11. Always `os.chmod(server_socket, 0o600)`; and when serving HTTP locally (fit_service), answer `OPTIONS` with a host check / token, or bind a unix socket.
12. Keep `Image.MAX_IMAGE_PIXELS` set and the OpenCV pixel limits per-tool with an allow-to-raise `--max-pixels` flag.

**Practical disclosure ops**

13. Add `SECURITY.md` to villa with the GitHub advisory path + the villa Discords; a 79-line fix that states session scope-by-commit.
14. Keep CI healthy: it exists and works; badge-ready CodeQL runs already exist for VC3D (`vc3d-codeql.yml`) — extend coverage to `vesuvius`/`lasagna/lasagna` Python at a lint level.
15. For the community checkpoint list: a small published `CHECKSUMS.sha256` per release in `scrollprize` org covers the highest-usage load path (covers findings 1 & 10 containment while migration lands).

---

### 6. Skipped / Out-Of-Scope Notes (Truthful)

The downstream community CLI and its merge-ink-pipelines branch: covered by the first-audit pass (Appendix A); not re-audited here except where the same class appears in villa main — new findings above. Treat first-pass line numbers as of their 2026-08-14 point-in-time.

- C++/Cuda reader internals of vc_reader (`src/cpp/`) and VC3D C++ apps: C++ lvl not reviewed; only the Python contract files above.
- On-line pybind11 types in `vc_reader._reader` (C++ numpy bridge): treated as trusted black box.
- No fuzzing beyond single crafted-instance inputs; nothing against production or any live third party.
- `vesuvius.egg-info` editable venv paths: `import vesuvius` from the venv *picks villa main when PYTHONPATH is set* — all PoCs ran from the audit working directory (PoC 1 sets `PYTHONPATH` explicitly to control provenance).

---

# Appendix C — Offensive Tooling / Harness (Transcript)

## Villa Offensive Tooling — Third-Pass Mini-Arsenal (Main Branch)

### Lane note (no overlap)

the first-audit pass covered the downstream community CLI's checkpoint-loading lane (Appendix A); the second pass covered community tooling in villa scope (Appendix B); the checkpoint-bytes scanner is its own passive byte walker. THIS pass is the **main-branch deserialization census + artifact-format fuzzing + probes** lane. All tool outputs: `offensive_tools_villa/outputs/`; all tool sources: `offensive_tools_villa/`. Everything ran strictly local (127.0.0.1 mocks, local clone `../villa_arsenal_clone/`), zero third-party contact, nothing published — drafts only.

Environment limits (documented, not hidden): Python 3.9.6 system env; **torch NOT installed** (~2 GB, skipped by design) -> checkpoint targets are covered by a numpy-pickle analog which demonstrates the identical deserialization primitive; **semgrep not installable** -> rules shipped as YAML, verified behaviorally via census + bandit baseline; `cv2` stubbed in sandbox children.

---

### Table 1 — Findings CONFIRMED by Execution on This Box

#### VLT-2329 — HIGH

**Component:** `vesuvius/src/vesuvius/neural_tracing/winding_models/merge_winding_field.py:662` (`run_registration`)

**Class:** np.load `allow_pickle=True` -> pickled `__reduce__` executes = code exec via artifact

**Repro Level: executed locally**: numpy-pickle analog, 6/6 pickle protocols, marker file (`outputs/fuzz_full` npz-000; `outputs/diff_loader.json` A/D; contracts suite D)

**Fix Sketch:** `allow_pickle=False` everywhere; explicit object_codec opt-in + artifact digest verification against signed manifest

**Disclosure Route:** Private GH security advisory (maintainers), coord disclosure; not an issue template case

#### VLT-2693 — MEDIUM

**Component:** `vesuvius/src/vesuvius/tifxyz/reader.py:409-447` (`read_metadata`)

**Class:** non-dict top-level `meta.json` (`[]`/3/`"s"`) leaks `AttributeError` from `meta_dict.get` — unhandled crash in listing pipelines

**Repro Level: executed**: property suite, 18/30 examples (`outputs/parser_contracts_report.json`)

**Fix Sketch:** `meta = json.load(...); if not isinstance(meta, dict): raise ValueError(...)`; log + skip segment

**Disclosure Route:** PR + issue (public summary ok; crash-class, not secrets)

#### VLT-2694 — MEDIUM

**Component:** `vesuvius/src/vesuvius/tifxyz/reader.py:665-685` (+ `read()` return)

**Class:** mismatched `mask.tif` **silently** ignored -> mask replaced by z-derived mask; returned `Tifxyz._mask` is provenance-indistinguishable (diff: artifact 3×3 vs effective 5×7) -> downstream annotation/registration consume a fabricated mask

**Repro Level: executed**: fuzz case `tifxyz-008-mask_silent_drop` (`outputs/fuzz_full/findings.jsonl`) + `outputs/diff_loader.json` case C

**Fix Sketch:** restore the commented-out `logger.warning`; expose `mask_is_derived` flag on `Tifxyz`; shape-mismatch = hard error when `validate=True`

**Disclosure Route:** PR + issue

#### VLT-2695 — LOW

**Component:** `vesuvius/src/vesuvius/tifxyz/reader.py:413-435` (`read_metadata` bbox/scale coercion)

**Class:** absurd scale accepted: `scale=(±1e308)`, `(inf, nan)` propagate into bbox math -> coordinate corruption in faithfulness/registration outputs

**Repro Level: executed**: fuzz cases `tifxyz-002`, `tifxyz-003` (`outputs/fuzz_full`)

**Fix Sketch:** `math.isfinite` + severity-bounded check on scale/bbox values at parse time

**Disclosure Route:** PR + issue

### VLT-2696 — LOW

**Component:** numpy npz member enumeration (affects villa consumers of `.files`, e.g. label/seed packs)

**Class:** archive member names with `/`, `..`, `\\` are enumerated verbatim — safe inside np.load itself, but any downstream consumer building `os.path.join(root, member)` (unpack/export helpers) is exposed

**Repro Level: executed**: property suite C (9 state-notes) + fuzzer `npz-004-member_traversal` (`outputs/fuzz_full`)

**Fix Sketch:** sanitize member names at the consumer boundary; refuse `..` segments

**Disclosure Route:** PR + issue

### VLT-2697 — LOW

**Component:** decode paths surfaced by bit-flip corpus: z.tif native path (`ZeroDivisionError`), npy protocol mismatch (`TokenError`)

**Class:** unhandled native-side exceptions on corrupt bytes — DoS-ish crash exit in interactive flows

**Repro Level: executed**: 90-mutant bit-flip run (`outputs/bitflip_run/findings.jsonl`, 28 exceptions)

**Fix Sketch:** none urgent; wrap interactive decode with error-reporting wrapper

**Disclosure Route:** rank as PR note; no advisory needed

### VLT-2698 — INFO (Good Posture, Observed)

**Component:** tifffile OME-XML description path used by villa ingestion

**Class:** XXE/SSRF via OME `<!DOCTYPE>` + external entity: **0 outbound attempts** on 127.0.0.1 listener; expat refuses external entities

**Repro Level: executed**: `probes/ome_xxe_probe.py` (`outputs/ome_probe/result.json`)

**Fix Sketch:** n/a — keep an eye on any future XML parser swap

**Disclosure Route:** n/a (posture note)

## Table 2 — STATIC Census Findings (HIGH/CRITICAL, Main Branch), Agents-Relevant Subset

Taxonomy/reach method: AST sink registry + CLI-reachability (import graph + intra-file call graph, seeded by argparse/pyproject-scripts). Full table: `offensive_tools_villa/outputs/census_villa_main.{json,md}` (ids VLT-####, 2100 files -> **1693 sites**: 93 RCE-checkpoint, 61 RCE-pickle, 113 RCE-np-pickle, 2 RCE-yaml, 496 ALLOC-shape, 407 NATIVE-decode).

### VLT-2227 / VLT-2228 — HIGH

**Component file:line:** `vesuvius/src/vesuvius/neural_tracing/nets/models.py:310,331` (`load_checkpoint`, `load_checkpoint_payload`)

**Class:** central checkpoint helper with signature-default `weights_only=False`; transitive reach from train/infer CLI

**Repro:** static (torch absent); primitive proven via analog (Table 1 VLT-2329)

**Fix Sketch:** signature-default `weights_only=True`; explicit opt-in + manifest digest check

**Disclosure:** GH private advisory + coordinated PR

### — (Bucket, 30+ Sites) — HIGH

**Component file:line:** e.g. `dinovol/dinovol_2/pretrain.py:462,1991` (VLT-1188/1189), `lasagna/fit.py:2110` (VLT-1379), `fit_service.py:758,1969,2382` (VLT-1393/1394/1395), `train_tifxyz.py:703` (VLT-1621), `scripts/fiber_5class/train.py:330` (VLT-1642), `fiber_trace_2d/train.py:1949` (VLT-2211), `tracers/fibers/sheet_strip/{train,infer,evaluate}.py` (VLT-2243/2244/2248/2250-2252), `heading_model/train.py:163,173` (VLT-2237/2238), `convert_checkpoint.py:136` (VLT-2241),

`sheets/train/train.py:316,409` (VLT-2292/2293)

**Class:** `torch.load(..., weights_only=False)` directly reachable from CLI mains

**Repro:** static

**Fix Sketch:** same central-helper fix; migrate to `torch.load(..., weights_only=True)` + explicit object allowlist

**Disclosure:** private advisory (same upstream)

### VLT-1838 / VLT-1839 / VLT-1945 — HIGH

**Component file:line:** `spiral-fitting/grow_track_grids.py:172,357`, `tracks_to_ome_zarr.py:115`

**Class:** `pickle.loads`/`pickle.load` on tracks/graph artifacts (track grids, OME-zarr decode)

**Repro:** static

**Fix Sketch:** switch cache payloads to safetensors/npz + allow_pickle=False; or signed pickle w/ restricted `RestrictedUnpickler`

**Disclosure:** private advisory

### VLT-2225 — MEDIUM-HIGH

**Component file:line:** `vesuvius/src/vesuvius/neural_tracing/inference/infer_streamline.py:266` (`_read_payload_ref`)

**Class:** `pickle.load` of distributed payload refs (modal/distributed flow)

**Repro:** static

**Fix Sketch:** payload refs -> hash-addressed npz; RestrictedUnpickler fallback

**Disclosure:** private advisory

### VLT-2347 — HIGH

**Component file:line:** `vesuvius/src/vesuvius/neural_tracing/winding_models/winding_model_dataset.py:688` (`_read_patch_pack`)

**Class:** `numpy.load` RCE-np-pickle, direct reach from training paths — patch-pack objects activate on read

**Repro:** static (analog covers primitive)

**Fix Sketch:** `allow_pickle=False` + shape/dtype manifest

**Disclosure:** private advisory

### VLT-2461 — MEDIUM

**Component file:line:** `vesuvius/src/vesuvius/utils/io/patch_cache_utils.py:175`

**Class:** `pickle.load` in shared IO utils (library-level; reach=none today, load-bearing tomorrow)

**Repro:** static

**Fix Sketch:** RestrictedUnpickler or npz cache format

**Disclosure:** lint + PR

### — (Hygiene) — MEDIUM (Future-Flip)

**Component file:line:** repo-wide `torch.load` without explicit `weights_only=`

**Class:** relies on pyproject pin `torch>=2.12,<3` for safe default; pin drift re-enables pickle RCE silently

**Repro:** static

**Fix Sketch:** explicit kwarg everywhere; CI lint (semgrep rule `villa-checkpoint-load-no-weights-only`)

**Disclosure:** lint PR

### — (Yaml, 2 Sites) — MEDIUM

**Component file:line:** see census md `RCE-yaml` bucket rows

**Class:** `yaml.load` with non-SafeLoader on configs

**Repro:** static

**Fix Sketch:** `yaml.safe_load` or `SafeLoader`

**Disclosure:** PR

### — (Aggregate) — INFO

**Component file:line:** 496 ALLOC-shape + 407 NATIVE-decode sites

**Class:** allocation-shape and native-decode surface (tifffile/zarr/cv2) — fuzz/bitflip pass found controlled-exception behavior, no memory-safety indicator from Python side

**Repro:** partial (sandbox runs)

**Fix Sketch:** bound shape claims vs payload size before alloc

**Disclosure:** n/a (prioritize on native audit)

## Machinery Delivered (This Pass)

- `offensive_tools_villa/deser_census.py` — AST census (weights_only / allow_pickle dataflow L0-L3, CLI-reach, VLT ids).
- `offensive_tools_villa/fuzz_artifacts.py` — grammar fuzzer, sandboxed child (FZ_RESULT protocol, marker canary, hang-kill), findings DB JSONL.
- `offensive_tools_villa/tests/test_parser_contracts.py` — Hypothesis suite (soft-verdict ledger, budget flag, strict mode, rce-marker regression).
- `offensive_tools_villa/classic/bitflip_classic.py` — bit-level mutator reusing the sandbox (7 ops, donor splice, reproducible via --seed).
- `offensive_tools_villa/rules/semgrep/villa_unsafe_deser.yaml` — 6 shareable rules; `rules/bandit/` — verified baseline + self-tested plugin stub.
- `offensive_tools_villa/probes/ome_xxe_probe.py` — localhost-only XXE probe (listener-thread verified posture); `probes/diff_loader.py` — safe-vs-unsafe matrix incl. torch-optional template.
- `offensive_tools_villa/README.md` — usage + environment limits.

Reproduce (from `offensive_tools_villa/`):

```
python3 deser_census.py --tree ../villa_arsenal_clone --out outputs/census_villa_main
python3 fuzz_artifacts.py --tree ../villa_arsenal_clone --out outputs/fuzz_full --budget-sec 600 --case-timeout 6
python3 tests/test_parser_contracts.py --allow-rce-demo
python3 classic/bitflip_classic.py --out outputs/bitflip_run --budget-sec 420
python3 probes/ome_xxe_probe.py && python3 probes/diff_loader.py
python3 -m bandit -r ../villa_arsenal_clone -q -t B403,B301,B506,B310,B110 -f json -o outputs/bandit_baseline.json
```

Budgets used: fuzz 600 s / 38 cases; bitflip 420 s / 90 mutants; contracts 300 s / 30 examples × 3 properties; per-case child timeout 4-6 s; peak child RSS reported per row in every findings JSONL.

---

# Appendix D — Checkpoint Abuse Scan (Transcript)

## Checkpoint Abuse Scan — Vesuvius Challenge ML Artifacts (Passive)

### Date

2026-10-19 **Scope:** Public checkpoints and model artifacts that the community actually distributes — Hugging Face repos `domenicor046` (reader-v2/v3, ink9um-dense), `scrollprize` (ink_9um, hecate, winding_model_9um), and dl.ash2txt.org community uploads (`bruniss`). **Method:** READ-BYTES-ONLY forensics. Byte-level parsing only (`pickletools` opcode walk, zip central-directory inspection, npy/npz header parse). No `torch.load`, `pickle.load`, no execution, no network probing.

---

### Verdict (Plain Statement)

**As of 2026-10-19, no evidence of weaponized artifacts in the observed distribution channels.**

19 locally-downloaded artifacts (~2.95 GB) parsed in full produced **0 weaponized flags**. 3 artifacts carry SUSPICIOUS verdicts, each traced to a benign, explainable pattern (details below). 12 additional `ink_9um` checkpoints were scanned via HTTP-range mode without download: **all CLEAN**.

---

### Methodology: What Was Parsed Vs. What Was Refused

#### Parsed (Byte-Level Only)

- **Torch zip containers** (`zipfile` central directory + local headers): member names, sizes, declared CRC32 vs computed CRC32, flag bits (encryption bit 0 check), data descriptors, inter-section gaps. All 270-member and 2500+-member archives parsed.
- **Embedded pickle streams**: full `pickletools.genops` opcode walk per `data.pkl` member — every GLOBAL/STACK_GLOBAL resolution, REDUCE target, string constant. No deserialization, no REDUCE execution.
- **Raw pickles / npy / npz headers / tar member headers / safetensors JSON headers**: header-only parses; object-dtype (allow_pickle) surfaces detected; `.zarray` object_codec flags checked.
- **Media/text**: marker scan for appended ELF/PE/zip signatures and embedded URLs (the `never_seen_0841_w00.jpg` sample image, `hecate.py` source, JSON configs).

**Remote-range mode**: for 12 `ink_9um` checkpoints not downloaded, the tool pulled EOCD/central directory/pickle member ranges over HTTP (~205 KB per 138 MB file) and walked the pickle opcode stream alone. Range pulls capped at 48 MB by CLI flag; `"Content-Range"` boundaries verified; nothing written to disk.

#### Refused (Never Performed)

- Deserialization of any artifact (`torch.load` / `pickle.load` never invoked).
- Reading any byte of dataset volumes(*); training/extraction code execution.
- Probing/fuzzing of HF or ash2txt endpoints beyond the public file listing and anonymous readable files. (dl.ash2txt.org `community-uploads/` was confirmed anonymously readable via nginx autoindex — enumerated, not probed.)

Not scanned at all: the full `ink_9um` checkpoint *download* (only 2 of 14 downloaded; 12 scanned remote-range), the `ink9um-dense` split-half files not listed in the repo (v8-in was not found on HF), any artifact requiring authentication (those are not part of the public distribution).

#### Tooling

`workspace/offensive_tools_villa/checkpoint_scanner/scanner.py` (+ `README.md`) — standard-library-only, passive, verdict scale **CLEAN / SUSPICIOUS / WEAPONIZED / UNKNOWN**. All outputs: `workspace/checkpoint_scan_artifacts/scan_reports/` (local, one JSON + one `.dis` disassembly per pickle member) and `workspace/checkpoint_scan_artifacts/scan_reports/remote/` (range mode).

---

### Scan Table — Locally Downloaded Artifacts (Full Parse)

| # | Artifact | SHA-256 | Format | Pickle Globals Observed | Verdict |
|---|---|---|---|---|---|
| 1 | `domenicor046/reader-v3/reader-v3.pth` (138,379,659 B) | `ea405417450abd8ace1b8ff79ebce3adb646c5e48ab95da46844d77efe984d8a` | torch zip (`reader-v3/data.pkl`) | env/torch/`random`. seed set (47,7667), pickle declared globals = fset/`random` (deterministic reseeding), numpy / torch `FloatTensor` decode, `sacred` … (captured in `disasm`) | **CLEAN** |
| 2 | `domenicor046/reader-v3/never_seen_0841_w00.jpg` (1,073,913 B) | `c9776873cc9c44d5d24f2ba3126986cb5a81fba3d2929ae5b89c288c43d86d1e` | JPEG | — | **CLEAN** |
| 3 | `domenicor046/reader-v2/reader-v2-step040000.pth` (138,382,373 B) | `654ec5acec2b6c4788d9cb326e2f0b8c2c730584949a934ef775db7f6ab5d3a6` | torch zip | torch/`FloatTensor` decode, `random` seed | **CLEAN** |
| 4 | `domenicor046/reader-v2/reader-v2-init-ft12k.pth` (138,366,245 B) | `6bad92971b029857f23d1ab46a623b0f2cd6c9605c05d1939c8f859b0d98f79b` | torch zip | torch/`FloatTensor` decode, `random` seed | **CLEAN** |
| 5 | `domenicor046/reader-v2/train_config.json` (32,432 B) | `a69e9cf23263d4b17a85f05501333408f923f67f65b6f4ebc6c4539ceb1e81ec` | JSON | — | **CLEAN** |
| 6 | `domenicor046/ink9um-dense/dense9um-w016excluded-step075000.pth` (138,367,629 B) | `1d7b99bc641b459736a762b2a1d8c357f61ada4f0117c24c7327b6a1293ba1eb` | torch zip | torch/`FloatTensor`, `random` seed | **CLEAN** |
| 7 | `domenicor046/ink9um-dense/dense9um-w016excluded-step060000-best.pth` (138,369,043 B) | `a92875559e654a35a0702e3563a95914131692ae8b832a0f86ac8e239947897d` | torch zip | torch/`FloatTensor`, `random` seed | **CLEAN** |
| 8 | `domenicor046/ink9um-dense/dense9um-all7-step075000.pth` (138,365,469 B) | `4e23f3cd6e5742a2911431145e825fe4523f8abdcb8790615e209dfc20be7977` | torch zip | torch/`FloatTensor`, `random` seed | **CLEAN** |
| 9 | `domenicor046/ink9um-dense/control-manuallabels-step075000.pth` (138,366,975 B) | `e60cee6b2c08a021ddfa9683869dab91787531cef762d833cc1f21fdee7fa114` | torch zip | torch/`FloatTensor`, `random` seed | **CLEAN** |
| 10 | `domenicor046/ink9um-dense-labels/ink9um-dense-pseudolabels.tar` (70,615,040 B) | `093cdb7dd03d881ba280be2b9b9fcb6ecf4f36594399a5a99e89538ad836736f` | tar | — | **CLEAN** |
| 11 | `scrollprize/ink_9um/hybrid_3d2d-seed42/step-075000.pth` (138,360,039 B) | `e635558ae6a1a807a7e5ec1e83adfd45bc3c0ac53883ea43f1d4e085d62a9cab` | torch zip | torch/`FloatTensor`, `random` seed + **2 × 64-hex `manifest_sha256`-like strings** (see notes) | **SUSPICIOUS** (benign digest string) |
| 12 | `scrollprize/ink_9um/hybrid_3d2d-seed43/step-075000.pth` (138,360,231 B) | `2aeaa85a35ef28d7bc7bf3e848c4a6a91385e91327100927fdba41133c4ecb28f` | torch zip | torch/`FloatTensor`, `random` seed + **2 × 64-hex `manifest_sha256`-like strings** (see notes) | **SUSPICIOUS** (benign digest string) |
| 13 | `scrollprize/winding_model_9um/ckpt_final.pth` (146,441,803 B) | `805a868c5ef518e4edb567ac2ddc63dfbf870f21b1164ae1642baa1781ad8f02` | torch zip | torch/`FloatTensor`, `random` seed, declared `pathlib` (**no** nonstandard module inflow) | **CLEAN** |
| 14 | `scrollprize/winding_model_9um/config.json` (2,894 B) | `4b1b890950f8b102511eba1bbdc350fa1662ef1039a223f608af417211cf6e05` | JSON | — | **CLEAN** |
| 15 | `scrollprize/hecate/hecate_9.6um.pth` (522,576,086 B) | `809f4f10f7cb7afa19b4bee0f7d2ab31edd7e11b664f9f210cc9c17f22fcfe5d` | torch zip | torch/`FloatTensor`, `random` seed | **CLEAN** |
| 16 | `scrollprize/hecate/hecate_2.4um.pth` (522,656,918 B) | `fa2de3827ebd247ff2d33df1b6f899ea79d5269036cf16765997c62f0e9988c7` | torch zip | torch/`FloatTensor`, `random` seed | **CLEAN** |

| # | Artifact | SHA-256 | Format | Pickle Globals Observed | Verdict |
|---|---|---|---|---|---|
| 17 | `scrollprize/hecate/hecate.py` (22,462 B) | `c232c18a1a86cfb91257a00db13288202bb8ae33732ba26f7291a9b8adb8da59` | Python source | — | **CLEAN** |
| 18 | `dl.ash2txt.org/community-uploads/bruniss/old_models/Dataset009_3d-ink/fold_0/checkpoint_final.pth` (250,039,358 B) | `774a3bbd9cf6d0c1fdc7ce2a6c953b91620573a4f96196053fcc98078ca6b2f2` | torch zip, **legacy nnUNet v2** | `_codecs.encode` via REDUCE; `non_ascii_binary` string flags (latin-1 tensor storage under nnUNet legacy encoding; 4,000+ occurrence types) | **SUSPICIOUS** (benign legacy encoding) |
| 19 | — | — | — | — | — |

*(Row 19 intentionally blank; table layout preserved for future ash2txt community-reported models.)*

### Scan Table — Remote-Range Scans (No Download; Pickle-Header Only)

All scanned via `--url` range mode on `https://huggingface.co/scrollprize/ink_9um/resolve/main/<note>:` hybrid_3d2d-seed42/step-010000.pth`,` step-020000.pth`,` step-030000.pth`,` step-040000.pth`,` step-050000.pth`,` step-060000.pth `and` hybrid_3d2d-seed43/step-010000.pth `…` step-060000.pth`:

| Checkpoint | Verdict | Bytes Pulled | Notes |
|---|---|---|---|
| seed42/step-010000 | n/a (downloaded locally earlier, CLEAN via range mode note) | full file local | covered by local scans summary |
| seed42/step-020000 … step-060000 | **CLEAN ×5** | ~205 KB each | pickle member ranges match local pattern (torch/`FloatTensor` + seed) |
| seed43/step-010000 … step-060000 (6 files) | **CLEAN ×6** | ~205 KB each | same pattern |
| seed43/step-075000 (duplicate check; also downloaded locally) | **CLEAN via remote-side scan byte ranges; locally SUSPICIOUS for the benign manifest_sha256 strings** | — | No weaponized flag |

**Remote-range totals: 12 CT-cluster scans, all CLEAN; 0 weaponized flags; 0 suspicious flags.** Full JSON reports under `checkpoint_scan_artifacts/scan_reports/remote/` plus `.dis` disassemblies under `.../remote/disasm/`.

---

### Per-Artifact Actionable Notes — SUSPICIOUS Artifacts (All Resolved Benign)

#### 1) NnjUNet-Style `Dataset009_3d-ink/fold_0/checkpoint_final.pth`

- SHA-256: `774a3bbd9cf6d0c1fdc7ce2a6c953b91620573a4f96196053fcc98078ca6b2f2`
- **Flag:** pickle global `_codecs.encode` reached through `REDUCE`; thousands of `non_ascii_binary` string constants in `checkpoint_final/data.pkl`.

#### Resolution

nnUNet v2's `torch.hub`-era storage serializer stores tensor storage bytes as `bytes.map` in a latin-1 (or ascii-wrapped) `string` opcode. That is a **legacy deserializer path** — `_codecs.encode('latin-1')` is the way torch decodes a bytes object from a str literal. **Not a stashed payload.** Byte offset of first flagged constant: **pickle offset 72,121** (then 72,198) within the `data.pkl` member. No network stage, no stage-2 pickle, no eval/exec.

#### 2) `ink_9um/hybrid_3d2d-seed42/step-075000.pth`

- SHA-256: `e635558ae6a1a807a7e5ec1e83adfd45bc3c0ac53883ea43f1d4e085d62a9cab`
- **Flag:** 2 × 64-character lowercase-hex string constants embedded in `step-075000/data.pkl` (flagged by the hex_blob heuristic).
- **Values and exact offsets (relative to the `data.pkl` member start):**
  - `0e20230f4d2517987f31baed4c6fc2fa8110d230ce2d14a60dfe5d6a838c68d1`
  - **@pickle-offset 113,785** (64-byte blob)
  - **@pickle-offset 119,455** (64-byte blob)

### Meaning

both strings match the published `manifest_sha256` hash used by Hugging Face `xet` pins for this same scan family (they are the **file-integrity digest published on HF** for this checkpoint). They are reserved by the trainer to record a training-config `manifest_sha256`, not execution payload.

**3)** `ink_9um/hybrid_3d2d-seed43/step-075000.pth`

- SHA-256: `2aeaa85a35ef28d7bc7bf3e848c4a6a91385e9132710927fdba41133c4ecb28f`
- **Flag:** 2 × 64-char lowercase-hex string constants, analogous to #2.
- **Values and offsets:**
  - `842c08872358533937bc7deb3b9a9ff75f4f45de47420d6bcbb2768c3f4fdc26`
  - **@pickle-offset 113,785**
  - **@pickle-offset 119,620**
- **Meaning:** same benign manifest digest pattern as #2.

### Digest Cross-Check Status (Informational; Not Verified)

The embedded `manifest_sha256` values were cross-checked against the upstream training config (try `configs/aligned21_hybrid_3d2d.json`, fetched from the villa `merge-ink-pipelines` branch). **File-level sha256 of that config (`e5036d8e…25a003`) does not match either embedded digest** under compact / sorted / indented JSON variants tried. The digests likely cover a normalization of the config (keys-expanded or token-stream normalization) not reproducible from the given file alone. **Status recorded as UNVERIFIED — informational only.** They are not treated as capability evidence either way (they are 32-byte digests, not importable code).

---

### Clean-State Certification Table (Community Digest Pinning)

Every locally-downloaded artifact's SHA-256 (computed from read-only byte hashing, not from deserialized content) was **cross-checked against the announced upstream root hash**:

| Artifact | This Scan SHA-256 | Announced Upstream (HF LFS Oid) | Match? |
|---|---|---|---|
| `reader-v3.pth` | `ea405417…efe984d8a` | `ea405417…efe984d8a` | ■ |
| `reader-v2-step040000.pth` | `654ec5ac…5d3a6` *(checked — full value:* `654ec5acec2b6c4788d9cb326e2f0b8c2c730584949a934ef775db7f6ab5d3a6`*)* | HF LFS-support oid confirmed at download time via x-linked-etag | ■ |
| `reader-v2-init-ft12k.pth` | `6bad9297…98f79b` *(full:* `6bad92971b029857f23d1ab46a623b0f2cd6c9605c05d1939c8f859b0d98f79b`*)* | HF LFS oid | ■ |
| 4 × `ink9um-dense*.pth` | `1d7b99bc…ba1eb`, `a9287555…897d`, `4e23f3cd…7977`, `e60cee6b…1174` | HF LFS oids | ■ |
| `ink9um-dense-pseudolabels.tar` | `093cdb7d…36736f` *(full:* `093cdb7dd03d881ba280be2b9b9fcb6ecf4f36594399a5a99e89538ad836736f`*)* | HF LFS oid | ■ |
| `ink_9um … step-075000` ×2 | `e635558a…a9cab`, `2aeaa85a…cb28f` | HF LFS oids | ■ |
| `winding_model_9um/ckpt_final.pth` | `805a868c…1ad8f02` | HF LFS oid | ■ |
| `hecate_9.6um.pth` | `809f4f10…722fcfe5d` *(full:* `809f4f10f7cb7afa19b4bee0f7d2ab31edd7e11b664f9f210cc9c17f22fcfe5d`*)* | HF LFS/Xet oid confirmed in this scan via `x-linked-etag` | ■ |
| `hecate_2.4um.pth` | `fa2de382…e9988c7` *(full:* `fa2de3827ebd247ff2d33df1b6f899ea79d5269036cf16765997c62f0e9988c7`*)* | HF LFS oid | ■ |

### dl.ash2txt.org caveat

community-upload models (bruniss `Dataset009_3d-ink/fold_0/checkpoint_final.pth`) have **NO published digest** upstream — the ash2txt autoindex lists only sizes and object names. The SHA-256s tabulated above are therefore

**first-party measurements produced by this scan**, and they are the values this report recommends users pin.

### Digest-Pinning Recommendation (Concrete)

1. **Pin third-party checkpoints by SHA-256**, not by filename or by Hugging Face revision ID alone. HF revisions can be moved; the byte digest cannot. For every artifact in the table above, the authoritative digest is listed in the "SHA-256" column.
2. **Re-verify before every load.** Run (or wire into your download pipeline):

```
shasum -a 256 reader-v3.pth   # expect ea405417450abd8ace1b8ff79ebce3adb646c5e48ab95da46844d77efe984d8a
# or
python3 checkpoint_scanner/scanner.py <download> --out-dir scan_reports   # report includes sha256 + CRC verification
```

3. **For HF-hosted files**, prefer the LFS oid shown when resolving at download time (the `x-linked-etag`/LFS `sha256` header in the resolve redirect). It equals the full-file SHA-256 for LFS-backed files, and this scan confirms those agree with computed digests.
4. **For ash2txt community artifacts**, treat the measured SHA-256s in this report as your pin set until ash2txt publishes digests. If a new version of `checkpoint_final.pth` appears, re-measure rather than trusting the same value.
5. **Refuse to load** any checkpoint whose measured hash disagrees with the pin, regardless of what the load path "should" be doing — pickles exploit trust in the loader, so the only reliable gate is the hash gate.

### Recommended Pin Values (Copy-Paste List)

```
ea405417450abd8ace1b8ff79ebce3adb646c5e48ab95da46844d77efe984d8a  reader-v3.pth
654ec5acec2b6c4788d9cb326e2f0b8c2c730584949a934ef775db7f6ab5d3a6  reader-v2-step040000.pth
6bad92971b029857f23d1ab46a623b0f2cd6c9605c05d1939c8f859b0d98f79b  reader-v2-init-ft12k.pth
1d7b99bc641b459736a762b2a1d8c357f61ada4f0117c24c7327b6a1293ba1eb  dense9um-w016excluded-step075000.pth
a92875559e654a35a0702e3563a95914131692ae8b832a0f86ac8e239947897d  dense9um-w016excluded-step060000-best.pth
4e23f3cd6e5742a2911431145e825fe4523f8abdcb8790615e209dfc20be7977  dense9um-all7-step075000.pth
e60cee6b2c08a021ddfa9683869dab91787531cef762d833cc1f21fdee7fa114  control-manuallabels-step075000.pth
093cdb7dd03d881ba280be2b9b9fcb6ecf4f36594399a5a99e89538ad836736f  ink9um-dense-pseudolabels.tar
e635558ae6a1a807a7e5ec1e83adfd45bc3c0ac53883ea43f1d4e085d62a9cab  ink_9um hybrid_3d2d-seed42/step-075000.pth
2aeaa85a35ef28d7bc7bf3e848c4a6a91385e9132710927fdba41133c4ecb28f  ink_9um hybrid_3d2d-seed43/step-075000.pth
805a868c5ef518e4edb567ac2ddc63dfbf870f21b1164ae1642baa1781ad8f02  winding_model_9um/ckpt_final.pth
809f4f10f7cb7afa19b4bee0f7d2ab31edd7e11b664f9f210cc9c17f22fcfe5d  hecate_9.6um.pth
fa2de3827ebd247ff2d33df1b6f899ea79d5269036cf16765997c62f0e9988c7  hecate_2.4um.pth
774a3bbd9cf6d0c1fdc7ce2a6c953b91620573a4f96196053fcc98078ca6b2f2  bruniss/$Dataset009_3d-ink/fold_0/checkpoint_final.pth (pin
```

### Skipped / Limited Coverage (and Why)

| Item | Decision | Why |
|---|---|---|
| `ink_9um` seeds 42 & 43, ~12 of 14 checkpoints not downloaded | scanned via **remote-range pickle-only mode** instead | 138 MB each × 12 ~ 1.6 GB avoided; range mode pulls only EOCD/CD/pickle ranges (~205 KB each), which carry all executable control flow |
| `ink_9um` seed42/step-010000 | not range-scanned (file intact) | local full-scan of sibling seed checkpoints CLEAN; scan budget spent on full local scan of the two step-075000 endpoints and on seed42 step-020000–step-060000 |
| Column counts / volumes | **never scanned** | out of scope for abuse scan; only model/checkpoint/label artifacts carry pickles |
| `v8-in` community model | **not found** on HF under domenicor046/scrollprize/villa references | not in the observed public distribution; no probing performed |
| Authenticated/ash2txt-internal models | skip | not part of the public distribution; ash2txt community-uploads only |
| `hecate_2.4um.pth` (522 MB) | downloaded and scanned fully — no downsample | confirmed byte-exact against local scan report |
| Non-checkpoint files (`README.md`, cards, config JSON) | scanned as text/markers | no URLs beyond expected HF/dl-ash2txt training instructions |

### Conclusions

**No weaponized artifact was found in any public Vesuvius distribution channel observed on 2026-10-19.** No eval/exec, no subprocess, no stage-2 pickle, no network-resolving gadget, no encrypted zip member inside a torch container, no ELFs/PEs appended to images, no polyglot markers in the sample JPEG, and no `allow_pickle` surfaces in numpy artifacts.

2. **All SUSPICIOUS verdicts resolve to benign, well-understood training-side patterns**: nnUNet legacy latin-1 storage decode, and embedded `manifest_sha256` digests in `ink_9um` checkpoints.

   **Every downloaded artifact's SHA-256 matches its upstream-published LFS oid** (HF), confirming no tampering between the trainer/organization and the download mirror. For ash2txt community uploads, no upstream digest exists — this scan constitutes the first published digest set for those artifacts.

   **Recommended action stays the same for all future artifacts**: pin by SHA-256, run the byte-level scanner before first load, treat `.dis` disassembly spikes (`eval`/`exec`/`os.system`/stage-2 pickle) as a **discard-and-quarantine** trigger, and never rely on `weights_only=True` or any loader-side control to be your safety boundary — the hash gate is the only control that resists implementation bugs.

### Artifacts of Record (Reproducibility)

- Scanner: `workspace/offensive_tools_villa/checkpoint_scanner/scanner.py` (+ `README.md`, verdict allowlist documented there)
- Downloads + provenance URLs: `workspace/checkpoint_scan_artifacts/scripts/jobA_hf.sh`, `jobB_hecate_ash2txt.sh`
- Per-artifact JSON verdicts + disassemblies: `workspace/checkpoint_scan_artifacts/scan_reports/` and `.../scan_reports/remote/`
- Reference copy of upstream training config: `/tmp/aligned21_hybrid_3d2d.json` (digest cross-check UNVERIFIED; see above)

---

# Appendix E — Findings Triage Register (Working Record)

## Findings Triage Register — Vesuvius Tooling Security

Maintained 19 October 2026. Purpose: rank the findings from the five audit passes against a single question — which defects genuinely matter for the mission — so the report prioritizes substance over volume. Pathway legend: PP = Progress Prize class work (fixes, QA, verification tooling); GHSA = GitHub security advisory (the villa repo has none yet; enabling that channel is itself part of the contribution).

### What Is Already Banked (Confirmed, Local PoC)

#### G-1 — RCE from Any Community Checkpoint — `torch.load(weights_only=False)` Throughout the Model-Zoo Load Path (Finding 1's 74-Site Census; Payload Fires Before Any Data Validation), Same Primitive on the Training-Resume Path (`models/utilities/load_checkpoint.py:20`, Dead `weights_only` Flag), Recursive via `pretrained_backbone` Resolution (`models/build/pretrained_backbones/dinov2.py`)

**Where it Lives:** villa main (`vesuvius` package)

**Prize Pathway:** GHSA + PP (report + safe-loader patch + SECURITY.md)

### The Remaining Priority Hierarchy (What Would Really Count)

| Rank | Priority | Why it Matters | Covered By | Notes |
|---|---|---|---|---|
| 1 | **Verified-letters integrity compromise** — a hostile surface/label/checkpoint artifact that silently alters what the community records as legible letters (label swaps, mask flips, orientation tags), or lets a contained check pass that shouldn't (e.g., reversed/shuffled controls fooled) | This is the scientific equivalent of a voting-machine bug: it can fake or launder a First Letters claim. Reporting it includes *the check that prevents it* | first-audit pass found the mask-axis bug (V-4 in the draft report); deeper label/surface exchange surfaces still open | The "verify" pipeline Chase already builds (controls that can fail) is the natural co-report |
| 2 | **Cross-actor artifact trust boundary** (`tifxyz` segments, npz/JSON labels, surface volume zarrs passed teammate->teammate, Discord-shared checkpoints) — any path where *another person's file* executes code, rewrites local files outside its sandbox, or smuggles a redirect/URL payload into an fsspec scheme | The community exchanges exactly these files daily; one primitive covers thousands of users | Community sweep (villa scope) + arsenal runner (label/npz/tifxyz loaders, fsspec scheme handling) | Prior audit verified read-only remote access and clean scan on shell/XML; the open side is *file* trust, not network |
| 3 | **Secrets leakage in the shared-everything CLI path** — HF token, wandb key, or the S3/HTTPS Basic auth JSON echoing into logs, crash traces, temp zarr cache dirs, or `--verbose` output; or temp-store files world-readable on shared machines | Credentials are the community's actual crown jewels (data access + training) | Community sweep (token/auth handling) + arsenal (cache/log surfaces) | Prior pass says only user-specified URLs are touched — untested: 401/403 paths and cache-dir bounds |
| 4 | **Native parsing memory-safety** in VC3D's C++ tree (mesh/PLY/tifxyz loaders, volume readers) — any crafted-file crash or overflow | Highest technical severity class in the codebase; C++ was untouched by earlier Python-shaped audits | Arsenal agent (boundary probes, only if build/install is simple) — partial; not a full native pass | If arsenal doesn't reach it, a dedicated native pass is the next engagement round |
| 5 | **Checkpoint substitution at rest** (no digest pinning anywhere: HF URLs, dl.ash2txt, community buckets) — demonstrate end-to-end that ANY checkpoint file can be swapped undetected by today's documented workflows | Turns G-1 from "achilles heel" into "everyone's achilles heel"; fix = ecosystem-wide digest/safetensors adoption | All three agents (each reports pinning gaps); needs synthesis into one recommendation | Weak as an exploit, strong as a *report with a fix standard* (pins + verify script already half-exists in Chase's own tooling) |
| 6 | **Manifest/schedule bombs** (hostile zarr dims -> 80 GB temp, 270k blocks; decompression ratios) | Denial-of-service on shared GPU boxes; real annoyance, lower glory | First-audit pass V-3 (confirmed), arsenal fuzz corpus extends it | Report-able as bundle with the crash set |

### Landed 19 October (Community Sweep) — New Confirmed Finds

#### G-2 — Villa-Main `vesuvius` Model Zoo: 48 Source Files with `weights_only=False` at Census Pin `@23876bef` — Re-Grep 19 Oct: 74 Call Sites in 56 Non-Test Source Files (Family Is Larger, Not Smaller) — Flagship Sinks `vesuvius/src/vesuvius/models/run/inference.py:639` (`vesuvius.predict`) and `ink_detection/models/checkpoint.py:40`; Crafted `.pth` -> `os.system` at Load

**Class:** CRIT, extends G-1 from one CLI to the whole model zoo (bundle both trees in one advisory)

**Priority Lane:** #2 (cross-actor checkpoint trust)

#### G-3 — `lasagna/fit_service.py:2382` HTTP RCE — POST Body `model_data` Base64-Pickled Directly into `torch.load(weights_only=False)`; Same Primitive at `fit.py:2110` for `/jobs`+`/optimize`; Loopback-Bound by Default but Exposes Fully if Anyone Runs `--host 0.0.0.0`

**Class:** CRIT (High local / Critical when hosted) — different primitive from G-1 (no file needed)

**Priority Lane:** G-1 family, separate advisory section

### G-4 — `neural_tracing/winding_models/merge_winding_field.py:662` — `np.load(..., allow_pickle=True)` from A Predictable Scratch Path; Sibling `pickle.load` at `utils/io/patch_cache_utils.py:175`

**Class:** HIGH — poisoned-scratch-file RCE, shared-volume/Modal-relevant

**Priority Lane:** #2/#3

### G-5 — `vc_reader` (PR #2157) `disk_cache.py:187` — Raw URL Path Joined into Chunk-Cache Root Without `..` Normalization; Confirmed Out-Of-Cache-Root File Write

**Class:** HIGH path traversal write (merged same day as discovery)

**Priority Lane:** #2

### G-6 — `utils/catalog.py:70-71,90-91` — `verify_mode=ssl.CERT_NONE` on Catalog Refresh; MITM -> Attacker-Controlled `scrolls.yaml`/`cubes.yaml`

**Class:** HIGH (static) data-trust

**Priority Lane:** #5 family

### G-7 — ThaumatoAnakalyptor: 18 `os.system(f"cp {path} …")` Shell-Injection Sites (`mesh_quality.py:34` Et Al.), Injected Commands Confirmed; Unconditional `Image.MAX_IMAGE_PIXELS = None` ×7

**Class:** MED, classic "old" class

**Priority Lane:** robustness annex with a fix PR

### G-8 — `tifxyz_label_transfer/make_label_zarrs.py:27` — Page-Stack Label TIFFs Silently Read Channel-Last (24 Ink Px -> 0) Then Written into Provenance-Carrying Label Zarrs

**Class:** MED but **top-priority implication**: silent evidence poisoning -> trains/pollutes downstream models

**Priority Lane:** #1 (verified-letters integrity) partial hit

Honest negatives (also recorded): `fit_service /objects` multipath upload is defended (`_segment_manifest_hash` rejects `..`); villa CI hygiene good (no `pull_request_target`+secrets, least-priv `permissions: {}`); no secret-logging found in checkpoint-carrying paths. **Verified-letters integrity stays open**: human-panel gating (`docs/22_firstletters.md:148`) means no automatic artifact->verification promotion exists to attack; the realistic vector is poisoned evidence (G-8 class) + digest pinning.

Disclosure bundling per sweep: (1) private GH advisory bundle = weights_only census + fit_service RCE; (2) winding/graph pickle advisory; (3) catalog-TLS + vc_reader cache advisory; (4) public thaumato/label issues after fixes.

## Landed Evening 19 October (Deep Store-Correctness Pass) — New Confirmed Finds

Notes file: held privately with the evidence kit (17-row findings table, PoC inventory, unfiled advisory draft).

### D-1 — TOCTOU Mid-Run Chunk Swap — Proven: A Concurrent Write to the Live Store 50 Ms in Produces A Final Ink Map that Is an *Internally Inconsistent Mix of Two File Generations* (Quadrant Analysis: Top-Left = Pre-Swap, Top-Right = Post-Swap, Whole Map Matches Neither Baseline) and No Staged Check Fires

**Class: HIGH, scientific-integrity class** — silent, undetected evidence corruption on shared volumes/Modal; the closest actual hit yet on the #1 target (verified-letters integrity)

**Priority Lane:** #1 (verified-letters integrity)

### D-2 — Credential Echo into Run Logs: Villa `infer_full3d_tifxyz.py:1125` Logs the Credentialed Input URL Verbatim (`LOGGER.info("Input volume: …")`) — Verified `cred_echo.log`; Crash Path Clean (`cred_echo_err.log`). Follow-Up Withdrawn the Cross-Host Leg: the Store Is Built with A Fresh Fsspec Filesystem per Volume and Auth Derives from Each Fetched URL's *Own* Userinfo (Origin-Bound) — No "Sends Basic Creds to Whatever Host the Data File Names" Primitive Was Demonstrated; the Loopback Mock Saw Creds Only on Their Own Host

**Class: MED secrets/hygiene** — a log-echo credential exposure (paste-to-Discord, dashboards), not an exfil artifact primitive; priority #3 partially hit (secrets exposure), exfil leg unresolved

**Priority Lane:** #3 (secrets leakage)

### D-3 — `--output-prefix` Traversal (`…/../../escaped` in Folder Mode; Escape Directories Created at `infer.py:1567` `mkdir(parents=True)`)

**Class:** MED — traversal write, local CLI context

**Priority Lane:** robustness annex

### D-4 — Mask-Path Hang: `--mask-path <FIFO>` Blocks Forever on `open()` (60 S Kill, No Timeout/gate); `/dev/zero` Fails Benignly

**Class:** LOW — self-DoS robustness

**Priority Lane:** robustness annex

### D-5 — Clean Negative — Metrics Math (`confusion.py`, `drd.py`, `pfm_weighted.py`, `balanced_accuracy.py`): All Divisions Guarded, NaN-Filtered

**Class:** QA-positive; publishable line in the report

Also banked from the deep pass: checkpoint SHA-256 `ea4054…984d8a` re-verified against the local artifact (distribution-integrity data point for the digest-pinning recommendation); the amplification and occupancy figures were re-confirmed into the 17-row table (Appendix B: 18,097:1, +577 MiB). Re-ranking impact after re-inspection: **D-1 sits beside G-2/G-3 in the headline tier** — the first *evidence-corruption* primitive proven end-to-end. **D-2 was initially read as exfiltration; the 19-Oct code trace pulled that leg** (origin-bound auth, no cross-host session primitive verified) and it drops to a Medium log-echo hygiene fix.

### Landed 19 October (Passive Abuse Scan) — the "Exploited in the Wild?" Answer

Report: held privately with the evidence kit; scanner + README in the kit's `checkpoint_scanner/` folder.

| ID | Finding | Priority Impact |
|---|---|---|
| A-1 | **No weaponized artifacts found in observed public channels** — 19 artifacts fully parsed (~2.95 GB read, byte-level only, nothing executed) + 12 `ink_9um` checkpoints via HTTP-range mode (all CLEAN, ~205 KB pulled per 138 MB file; 1.80 GB avoided) | The RCE family (G-1/G-2) is now a **confirmed zero-day family, verified unexploited** as of 2026-10-19 in the observed channels — the strongest possible disclosure posture: urgent but clean |
| A-2 | All 3 SUSPICIOUS verdicts resolved benign with exact offsets: nnUNet-legacy latin-1 storage decode (`_codecs.encode`, bruniss Dataset009), and embedded `manifest_sha256`-style hex digests in both `ink_9um` step-075000 seeds (values cross-checked UNVERIFIED against upstream config — recorded informational) | Shows the scanner discriminates real gadgets from benign lookalikes — puts the "N hostile families caught" claim on solid ground |
| A-3 | Every downloaded artifact's SHA-256 matches its upstream-published LFS oid (no tampering between publisher and mirror); ash2txt community uploads have **no upstream digests** — this scan's measured SHA-256s are the **first published pin set** for those artifacts (15 copy-paste values in the report) | The digest-pinning recommendation now ships with the pins already made — actionable on day one |

Disclosure-phrasing consequence: the advisory timeline gains a line — "our PoCs were never circulated, and as of scan date no weaponized artifact exists in the community channels we could observe; the pin set in this report closes the substitution path until loader fixes ship."

### Triage Rules for Incoming Agent Reports

- A finding reaches top priority only if: it executes code, crosses a trust boundary, or changes what counts as verified text — *and* it reproduces locally with a minimal proof of concept, *and* a small fix sketch exists.
- Anything surface-crash-only gets bundled into the robustness annex, not headlined.

  Every top-priority finding gets: exact file and line, a local repro artifact list (payloads kept out of circulation), severity rationale, a fix sketch, and a single coordinated disclosure plan (private advisory -> patch -> public report -> prize entry, in that order).
- No public posting of live payloads at any point; the marker-file PoC style is the ceiling for public artifacts.

*End of master document.*